

Research Methodologies for Cybersecurity in Enterprise Environments: A Narrative Review, Synthesis and Executable Guide

Tran Duc Le

Department of Mathematics, Statistics & Computer Science
University of Wisconsin-Stout Polytechnic
let@uwstout.edu

Abstract—Enterprise cybersecurity research draws on a wider range of methods than any single community routinely teaches: a study may need a systematic review, a design-science artifact, an interview study, a controlled detection experiment, an attack-graph model, a testbed deployment, or a randomised field trial, and increasingly several of these at once. Researchers entering the field therefore face a selection problem before they face a technical one. This paper addresses that problem in two ways. First, it is a narrative review and synthesis of the methodological practice visible in a corpus of 151 works whose identifiers were all checked against a registry before inclusion, organising that practice into eleven families and reporting, for each, what the family answers, how strong the supporting evidence is, and where it fails. Second, it converts each family into an executable protocol: ordered steps, the instruments and formulas the steps require, the evaluation criteria that make a result defensible, the validity threats that most often invalidate it, and a reporting checklist. Every protocol is also drawn, so that the sequence of steps, the decisions that branch it and the threats that attach to each step are legible before the prose is read. We also treat the contradictions in the literature as evidence in their own right. The reported ranking of intrusion-detection algorithms is inconsistent across studies that are individually careful: one comparison places random forest at 99.9% accuracy above convolutional and recurrent networks at 98%, another places deep feed-forward networks first, and a third places recurrent networks first. We argue that the pattern is most parsimoniously explained by evaluation design rather than by the algorithms, because the studies differ in every design dimension known to move the reported number by more than the margins that separate them. The evidence supports methodological pluralism disciplined by explicit validity reasoning: match the design to the decision under study, triangulate technical against organisational evidence, state the population a result generalises to, and report the conditions under which the result would not hold.

Index Terms—Research methodology, enterprise security, narrative review, research synthesis, design science, threat modeling, intrusion detection, evaluation, reproducibility, validity.

I. INTRODUCTION

ENTERPRISE cybersecurity is the protection of an organisation’s information, systems, networks, applications, operational technology and cyber-physical assets against events that would compromise confidentiality, integrity, availability, safety or continuity of business. Modern enterprises depend on distributed information systems, cloud services, container platforms and networked operational technology. Those dependencies enlarge the attack surface and, more importantly

for a researcher, create relationships in which a weakness in one component determines the consequences in another. Critical infrastructure makes the point sharply, because a cyber event there propagates into physical process and operational disruption [1], [2].

Research in this setting is correspondingly broad. It includes security assessment, penetration testing, threat modeling, attack simulation, risk quantification, security assurance, incident response, security operations, human factors, training and governance. Assessment has been characterised as the activity that establishes assurance that vital cyber assets are effectively protected, and threat modeling as the systematic identification of vulnerabilities, threats, attack paths and countermeasures [3], [4]. Cyber-threat intelligence extends this by turning threat information into intelligence that supports organisational decisions, although its uptake has remained concentrated in information-technology operations rather than across enterprise practice [5].

A. The problem this paper addresses

The methodological diversity of the field is not itself a problem. The problem is that the families evaluate different outcomes and rarely explain themselves to one another. Accuracy and F_1 dominate machine-learning work; incident-response studies measure coordination, response speed and organisational learning; risk modeling reports probabilities, resilience or time-to-compromise; training research measures engagement and knowledge retention. A researcher who has been trained in one of these traditions has little basis for judging when it is the wrong instrument. The consequence is visible in the literature: studies that answer a question nobody asked, technically careful experiments whose results do not transfer out of the benchmark that produced them, and organisational studies whose conclusions cannot be checked.

The field has known this for a long time. An early analysis of why information-security research was scarce reported that firm-level security is an unusually sensitive research domain and documented a failed attempt at empirical validation as its principal result [6]. Two decades later, a systematisation of knowledge on security as a scientific pursuit argued that the field’s difficulty is not a shortage of technique but a shortage of clarity about what would count as evidence [7]. This paper is written in that spirit and at a more practical level.

B. Scope

We restrict attention to methodology, the design, conduct, evaluation and reporting of a study, rather than to security techniques. A paper proposing a better detector is in scope only insofar as it demonstrates how such proposals should be evaluated. We further restrict attention to enterprise and organisational settings, including the cyber-physical enterprises (grids, hospitals, transport, shipping, industrial process) that serve as proxies where a general enterprise population is inaccessible.

We do not impose a publication-date window, nor do we characterise one. A narrative review is selected for methodological standing rather than assembled to fill a span of years. A date range describes the corpus without licensing statements about the period, as a selective review cannot offer comprehensive coverage between endpoints. Most of the works discussed here are recent, the corpus median publication year is 2020 and 58 of the 151 works date from 2023 onward (Table I), because most of the methodological argument is; the foundational statements are included wherever a current method rests on one, and are identified as such where they appear.

C. Contributions

- 1) A methodology taxonomy of eleven families for enterprise cybersecurity research, each mapped to the class of research question it answers and the class of claim it licenses (Section III).
- 2) An executable protocol for each family, ordered steps, instruments, formulas, evaluation criteria, validity threats, observed failure modes and a reporting checklist (Section IV–Section XIV).
- 3) A drawn form of each protocol, in a single visual vocabulary, showing the ordered steps, the decisions that branch them, the artifact each step must produce and the validity threat that attaches to it (Figure 1–Figure 16). The figures are the part of this paper intended to be usable at the point of designing a study, rather than read once.
- 4) A worked analysis of the clearest contradiction in the corpus, the inconsistent ranking of intrusion-detection algorithms, showing that the contradiction cannot be resolved by choosing a winner and that headline benchmark accuracy is therefore not a stable estimate of enterprise performance (Section XVII).
- 5) Three end-to-end study recipes that combine families, for readers who want a starting template rather than a taxonomy (Section XVIII).
- 6) A reference corpus in which every entry was verified against a registry before inclusion, with the procedure and its failures reported (Section II-D).

D. How to read this paper

A reader who already knows which method they need should go directly to that family’s section; the sections are self-contained, each carries a figure of its protocol, and each ends

with a checklist. The figures share one vocabulary throughout: a blue box is a step, an amber box is a decision the protocol forces you to make explicitly, a green box is an artifact the step must produce, and a red italic box is the validity threat that attaches to that step. A dashed arrow is an iteration back to an earlier step. A reader who does not should read Section III, which contains the selection procedure, and then follow it. A reader who is reviewing someone else’s work will find Section XVI (validity, reproducibility, ethics, claim discipline) and the checklists in Appendix A the most directly usable parts.

By *executable* we mean followable: ordered, gated, and with each step’s required output stated, so that a study can be designed against them directly. The protocols are not software; the checklists and figures are the form in which they are meant to be used.

II. HOW THIS REVIEW WAS CONDUCTED

Family A (§IV) requires a review to report its own procedure; accordingly, this section states the review type and why it was chosen, how the literature was found and screened, how references were verified before inclusion, and how the synthesis was produced.

A. Review type, and why this one

This is a *narrative review and synthesis*, and the label records a methodological commitment. Snyder’s account of literature review as a research methodology in its own right distinguishes the systematic, semi-systematic and integrative forms by the question each can answer: a systematic review answers a narrow question where the primary studies are commensurable enough to be appraised against a common instrument, whereas an integrative or narrative synthesis is the appropriate form when the purpose is to map and critique a body of work that spans research traditions [8]. Our question, which methodology should be used for which enterprise-security research decision, and what does each license, is of the second kind. The primary studies here include controlled detection experiments, interview studies, Delphi panels, simulations and maturity models. There is no shared outcome measure across them and no risk-of-bias instrument that applies to all of them, so a systematic protocol would either exclude most of the field or apply an appraisal instrument outside its domain of validity.

The narrative form has its own standards, and they are not the absence of standards. Green et al.’s guidance for narrative reviews in peer-reviewed journals fixes the obligations: state the purpose, state how the literature was found, and make the basis of selection visible to the reader rather than implicit in the author’s expertise [9]. Ferrari adds the requirement that a narrative review declare its own susceptibility to selection according to the author’s viewpoint [10], which is the specific weakness of the form. Barry et al.’s six-step approach to state-of-the-art review supplies the operational structure we follow, delimit the field, search, screen, extract, synthesise, and state what the synthesis does not cover [11]. Where a narrative synthesis needs the retrieval discipline of a systematic one

without its appraisal apparatus, Turnbull et al.’s systematic-narrative hybrid describes exactly the combination used here: a documented, reproducible search feeding an interpretive synthesis [12]. The RAMESES publication standards for meta-narrative review are the closest existing reporting standard to what this paper does, and we follow their reporting logic, rationale, scope, search process, selection, appraisal approach, synthesis process, even though the review is not itself a meta-narrative one [13], [14].

Three consequences follow, and we state them here rather than only in the limitations. This review does not claim completeness of coverage. It does not claim that the eleven families partition the field without remainder. And its confidence labels (Section II-E) are reasoned judgements against stated definitions, not scores from a validated instrument.

B. Sources and retrieval

We searched three bibliographic databases: OpenAlex (for cross-publisher coverage and citation context), Semantic Scholar (for semantically-related work), and arXiv (for methodological work in security that appears as a preprint before, or instead of, a venue). General web search was not used as a literature source. We queried one methodology facet at a time rather than as a single broad query, for example *cyber range testbed security experiments*, *Delphi study cybersecurity experts consensus*, *temporal bias malware classification*, because long multi-clause queries returned unrelated work.

What this review does not report, and should: the complete search record, the wording of each query, the date it was run and how many records it returned in each of the two rounds, together with how many candidates were screened down to the 151 included works, is not printed here and not yet released alongside the preprint. Family A’s protocol (Section IV) requires a review to record and report exactly that, and this version does not meet its own standard; the three example queries above illustrate the style of search only. The repair is to release the full search record as supplementary material; of the selection record, only the aggregate verification outcomes are reported (Section II-D), together with the two identifier failures the check caught and their resolution.

A prior thematic synthesis prepared for this project contributed a seed set of 49 works covering assessment, modeling, detection, human factors and operations. That seed set was not accepted on trust: every one of its references was independently verified by the procedure below, and its factual claims were checked against publisher-hosted abstracts before any of them were carried into this paper. Section II-G reports the outcome of that audit, including the one part of the antecedent synthesis we declined to reproduce.

C. Inclusion criteria

A work was included if it satisfied all of:

- 1) **Security focus.** It addresses cybersecurity, information security or a directly adjacent security research problem, or it is a methodological foundation (for example inter-rater reliability, mapping-study guidelines) that security research demonstrably depends on.

- 2) **Enterprise relevance.** It investigates an organisational, business, production-scale or cyber-physical enterprise setting, or supplies a method explicitly applicable to one.
- 3) **Methodological explicitness.** It describes a research design, evaluation procedure or reproducible methodological approach, rather than presenting only an artifact or a threat survey.
- 4) **Sufficient detail.** It reports enough about procedure, data, instruments or implementation to inform the design of a new study.
- 5) **Stated evaluation.** It evaluates its own contribution against stated metrics, comparisons, case evidence or expert judgement.

D. Verification procedure

Before we included any reference, we checked it against its source record:

- 1) For each Digital Object Identifier (DOI) we looked up the record and compared the first-author family name, publication year, title and container title against the citation we intended to record.
- 2) We did the same for each arXiv identifier.
- 3) We then built the bibliography from the source record itself, so that a metadata field could not silently diverge from the source.
- 4) Numeric claims carried over from the seed synthesis were checked against the publisher-hosted abstract of the cited work.

The check is inexpensive and it caught real errors. Two candidate identifiers failed the check: one did not resolve at all, and one turned out to refer to an entirely different paper than the one intended, a class of error that no amount of proofreading detects, because the citation string looks correct. Both were excluded rather than repaired from memory.

We searched and selected in two rounds, the second after the taxonomy was complete, which is the point at which the gaps in the first round become visible: the reporting standards each family should be written against, the methodology literature for the review form itself (Section II-A), and the primary-method exemplars for the families that the first round had covered thinnest. All 41 works added in the second round checked out. The second round also recovered one of the two earlier failures. The identifier that had turned out to refer to an unrelated paper belonged to a work we still wanted, a systematisation of benchmarking flaws in systems security [15], and searching for the work rather than repairing the string located the correct record. That is the right order in which to do it, and the wrong order is what produces a citation that looks clean and points somewhere else. Of the 151 works we included, 129 were verified against their DOI record and 22 against their arXiv record.

Five references carry a year discrepancy of one between the online-first date frequently cited in secondary literature and the issue date of record (for example, a cyber-range review cited as 2019 that carries a 2020 issue date). We use the issue date reported in the registry throughout, which is why some years here differ by one from the same work cited elsewhere.

TABLE I
COMPOSITION OF THE 151-WORK CORPUS, COUNTED FROM THE
VERIFIED BIBLIOGRAPHY.

Publication period	Works
1977–2009	19
2010–2014	16
2015–2019	34
2020–2022	24
2023–2026	58
Venue type	Works
Journal article	97
Conference paper	25
Preprint or other unindexed	23
Technical report	2
Book	2
Book chapter	2

Table I records what can be counted directly from the verified bibliography: the corpus spans 1977–2026 with a median publication year of 2020, and 58 of the 151 works date from 2023 onward. The distribution describes this review’s selection, not the field: the corpus was assembled by the judgement and the facet-by-facet search described above, so these counts are provenance for the frequency characterisations in the family sections, not estimates of the literature’s composition.

E. Synthesis

For each work we recorded the methodology family, research design, enterprise context, data sources, procedure, evaluation instrument, principal finding and stated limitations. Synthesis was thematic. We did not compute a pooled effect estimate, because the outcome measures across families, accuracy, time-to-compromise, maturity level, κ , perceived usefulness, are not commensurable, and a single number would have had no interpretation.

Each thematic claim in Section IV–Section XIV carries a confidence label. We use three levels, defined as follows. *Strong*: multiple independent studies, consistent direction, method transparent enough to be checked. *Moderate*: consistent direction but with dependence on context, expert input or single-site evidence. *Limited*: supported by one study, by formative evaluation only, or by evidence whose population differs materially from the enterprise population the claim addresses.

The scheme is modelled on Grading of Recommendations, Assessment, Development and Evaluation (GRADE), which rates a body of evidence rather than an individual study and separates the quality of that evidence from the strength of the recommendation drawn from it [16]. We borrow the separation and the practice of recording the reason for each rating, but not the instrument: GRADE’s downgrading criteria assume comparable outcome measures across studies, which is precisely the condition this corpus does not satisfy. The labels here should therefore be read as structured editorial judgement, checkable against the definitions above, and not as instrument scores.

F. Limitations of this review

This is a narrative synthesis, not a meta-analysis, and it inherits six limitations. First, and definitionally, the corpus is selected rather than exhaustive. A narrative review is assembled by judgement, and judgement is where the author’s own background enters the result [10]; ours is in security engineering and empirical software engineering, which is visible in how much space the detection and experimentation families receive relative to, say, security economics. A reader should treat the eleven families as a defensible partition of what we found, not as a census of what exists. Second, retrieval was facet-by-facet and relied on database search; a facet we did not formulate is a facet we did not cover, and we name the ones we know we under-covered in Section XIX. Third, no formal risk-of-bias instrument was applied to the included studies; the confidence labels are our reasoned judgement against the definitions above, not an instrument score. Fourth, the corpus over-represents work that publishes its method, which is a form of selection: a widely-used practice that nobody writes up is invisible here. Fifth, we did not obtain the full text of every included work; where extraction rested on an abstract or a structured record, the corresponding claim is labelled at most *Moderate*. Sixth, extraction and family assignment were performed by a single coder. The frequency characterisations the family sections rely on (“mostly”, “predominantly”) are one systematic reading of the 151 works, not counted or reliability-tested estimates; Table I reports what could be counted directly from the verified bibliography, and a double-coded sample of the family assignments is the obvious strengthening.

Because the first of these is the form’s characteristic weakness rather than an incidental one, we make the compensating move that the narrative-review guidance recommends [9], [11]: the retrieval procedure, the inclusion criteria, the verification record and the explicit statement of what we under-covered are all reported above and in Section XIX, so that the selection is inspectable even though it is not exhaustive.

G. Audit of the antecedent synthesis

Because the seed synthesis materially shaped Section IV–Section XIV, we report its audit explicitly.

All 49 of its references checked out, and in every case the first author, title and venue matched the citation. None was fabricated. Its load-bearing numeric claims also held verbatim against the publishers’ own abstracts: the comparison reporting 98% accuracy for convolutional and recurrent models against 99.9% for random forest [17]; the hybrid ensemble reporting accuracy, precision, recall and F_1 approaching 100% under Synthetic Minority Over-sampling Technique (SMOTE), weighted soft voting and five-fold cross-validation, with independent benchmark evaluation [18]; the awareness-metric framework derived from a review of 32 papers adapting four indicators, impact, sustainability, accessibility, monitoring [19]; and the four-week experience-sampling design behind the within-person treatment of neutralisation theory [20].

One part we declined to reproduce. The antecedent synthesis reported a study-selection flow of 400 records identified, 200 screened, 150 excluded and 50 included, which implies that

no work was excluded at full-text assessment, an outcome that essentially does not occur in a real screening process. Its own limitations section conceded that the stated totals exceed the records whose data are presented. We therefore treat those figures as unsupported and do not restate them, here or as a description of our own retrieval. The episode is a useful illustration of the paper’s own argument: a reference list can be completely clean while the process narrative around it is not, so the two need separate checks.

III. A TAXONOMY AND A SELECTION PROCEDURE

A. Eleven families

Table II maps the families to the question each answers and the claim each licenses. The final column is the one most often ignored: a method licenses a specific form of statement, and a study that draws a stronger form has made an error that no amount of technical care repairs.

B. Selection procedure

Method follows the decision under study, not the researcher’s training. The following procedure is deliberately mechanical.

- 1) **Write the claim you intend to end up making**, in one sentence, in the past tense, with its population and its conditions attached. If the sentence cannot be written, the study is not yet defined and no methodology can be chosen.
- 2) **Classify the claim**. Descriptive (what exists), associational (what varies together), causal (what changes what), constructive (what can be built), or comparative (which of these is better under stated conditions).
- 3) **Read the licensing column** of Table II and eliminate every family whose licensed form is weaker than the claim you wrote.
- 4) **Check feasibility of access**. Enterprise research is access-bound far more than it is technique-bound. Determine what you can actually obtain: production telemetry, practitioners’ time, a testbed, a workforce to randomise, or only public artifacts. Eliminate families whose data you cannot get.
- 5) **If more than one family survives, take two**. Triangulation across a technical and an organisational family is the recurring recommendation of this corpus, and it is what distinguishes the studies whose conclusions survive contact with practice.
- 6) **Pre-specify the negative result**. State now what observation would make you report that the approach did not work. A design that has no such observation is not an evaluation.

Step 6 deserves emphasis. Across the corpus, in our coding of it (Section II-F), the studies whose findings we labelled *Limited* are mostly those in which the evaluation could only have come out one way. Figure 1 draws the procedure, including the loop that most study designs need at least once: if no family survives the access check, the claim is the thing that has to be renegotiated.

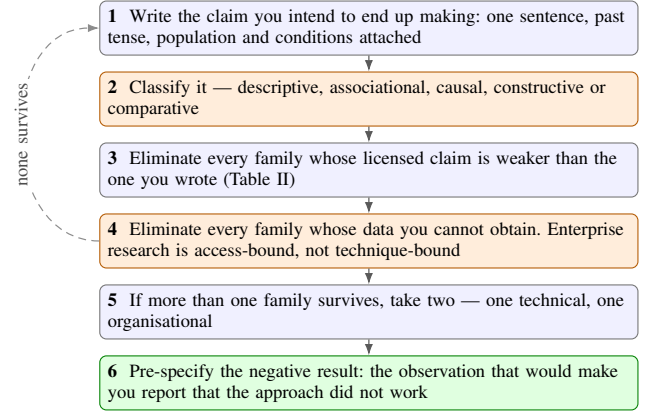


Fig. 1. The selection procedure of §III, which runs before any method is chosen. The two amber steps are the ones researchers skip: a claim that has not been classified cannot be matched to a family, and a family whose data cannot be obtained is not a candidate however well it fits. If step 4 eliminates everything, the claim, not the method, is what has to change.

IV. FAMILY A: SECONDARY RESEARCH

A. Purpose and when to use it

Secondary research synthesises existing studies. Use it when the question is about the state of knowledge, what methods exist, how they are evaluated, what is missing, rather than about the world directly. In this corpus it is the principal landscape-building method, applied to assessment methods, machine-learning detection, cyber ranges, penetration testing, threat intelligence, awareness programmes and organisational implementation factors [3], [21]–[24].

Three variants are worth distinguishing. A *systematic literature review* answers a focused question and appraises the evidence. A *systematic mapping study* answers a broader question by categorising a field without deep appraisal, and is the right choice when the field is too immature for synthesis [25]. A *systematisation of knowledge* (SoK), the security community’s own form, reorganises a field around a conceptual contribution rather than around a protocol; the SoK on evaluations in industrial intrusion detection and the SoK on algorithmic red teaming are recent instances [26], [27].

B. Protocol

- 1) **Formulate the question** in PICO-like terms adapted to computing: population (which systems, which organisations), intervention (which method or technique), comparison, outcome (which measured property).
- 2) **Write and register the protocol before searching**, including the query strings, the databases, the inclusion and exclusion criteria, and the extraction form. Deviations discovered later are reported as deviations rather than retrofitted.
- 3) **Search**. Use at least two indexing services with different coverage models. Record the exact query string, the service, the date and the hit count for each. In security, add the preprint servers explicitly: a substantial part of current methodological work appears there first.
- 4) **Snowball**. Backward snowballing follows the reference lists of included works; forward snowballing follows

TABLE II
METHODOLOGY FAMILIES, THE QUESTIONS THEY ANSWER, AND THE CLAIMS THEY LICENSE.

Family	Answers the question	Primary output	Licenses a claim of the form
Secondary research (§IV)	What is known, and where are the gaps?	Taxonomy, map, gap agenda	"The published literature reports ..."
Design science (§V)	Can an artifact be built that solves this class of problem?	Artifact plus evaluation	"This artifact achieved ... in this evaluation setting"
Qualitative inquiry (§VI)	Why do practitioners act as they do?	Themes, models, mechanisms	"In these settings, participants described ..."
Survey and behavioural (§VII)	How is a construct distributed, and what predicts it?	Estimates, path coefficients	"In this sampled population, X was associated with Y"
Threat modeling and risk (§VIII)	Which paths exist, and what would they cost?	Threat set, attack graph, probability	"Under this model and these inputs, ..."
Simulation and model-based (§IX)	How does the system behave under attack?	Trajectories, sensitivities	"In the modelled system, ..."
Machine-learning experiment (§X)	Does this detector work, and under what conditions?	Metrics with confidence bounds	"On this data, under this split, ..."
Language-model and agentic evaluation (§XI)	Is this language-model-based system fit for the task?	Benchmark result plus validity analysis	"Under this uncontaminated protocol, ..."
Measurement and telemetry (§XII)	What can actually be observed in practice?	Coverage and efficacy measures	"With this telemetry, this fraction was detectable"
Experimental infrastructure (§XIII)	Where can this be tested safely and repeatably?	Testbed, range, emulation plan	"This result is reproducible on this configuration"
Field experiment and training (§XIV)	Does the intervention change behaviour?	Effect estimate, learning outcome	"Assignment to the intervention changed ..."

their citers. Wohlin's guidelines make the start set and the iteration explicit and are the standard reference for doing this reproducibly [28]. Snowballing routinely recovers work that keyword search misses because the community uses a different vocabulary.

- 5) **Screen** in two stages, title/abstract, then full text, with a second screener on a sample, and report the agreement (Section VI-D). Record the exclusion reason at full-text stage for every excluded work.
- 6) **Extract** using the pre-specified form. Pilot the form on five papers and revise before the full pass.
- 7) **Synthesise**. For a review, thematic synthesis with an auditable coding step is the workable default; Cruzes and Dybå's recommended steps adapt it to engineering literature [29]. For a mapping study, produce the classification and the frequency distributions.
- 8) **Report** against the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 statement [30], including the flow of records through identification, screening, eligibility and inclusion.

The protocol is illustrated in Figure 2.

C. Instruments

The reporting standards worth knowing are PRISMA 2020 for reviews of any kind [30], Kitchenham's software-engineering adaptation of systematic review procedure [31], Petersen's mapping-study guidelines [25], and ROSES where an environmental-evidence style protocol is preferred, as in the thematic cybersecurity framework of [24].

Two companions to PRISMA are worth naming because they cover the cases security reviews most often fall into. PRISMA-P specifies what belongs in the *protocol*, the document written at step 2, before any searching, and is the instrument that makes step 2 an artifact rather than an intention [32]. PRISMA-ScR extends the reporting items to scoping

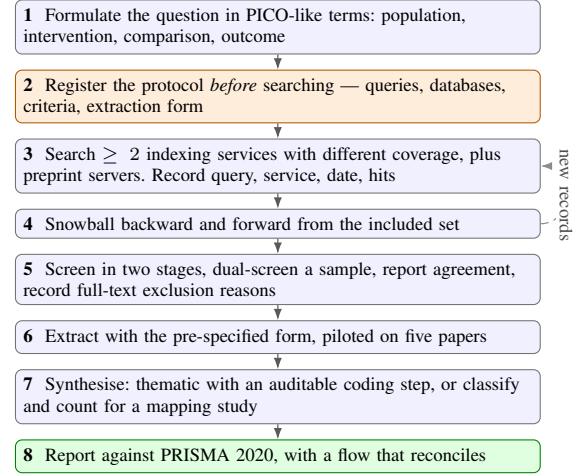


Fig. 2. Family A. The two steps that decide whether the review is checkable are 2 and 5: a protocol written after the search cannot constrain it, and a screening stage with no recorded exclusion reasons produces a flow diagram that no reader can audit. Snowballing feeds records back into screening, which is why the search cannot be closed before it.

reviews, which is the correct label for a large share of what the security literature calls a survey: a review that maps the extent and nature of a field without appraising the strength of its evidence [33]. Choosing the standard is part of choosing the design, not a formatting decision taken at submission.

D. What the evidence supports

Confidence: Strong that secondary research is effective for mapping a methodological landscape, identifying taxonomies, comparing evaluation measures and exposing gaps. **Confidence: Moderate** for any conclusion a review draws about comparative effectiveness, because a review inherits the dataset limitations and reporting inconsistencies of the

studies it summarises. Reviews of network intrusion detection repeatedly identify exactly this: variation in datasets, metrics and reproducibility that prevents the underlying results from being compared [21], [34], [35].

E. Failure modes

- **The flow diagram that does not reconcile.** If the numbers in the PRISMA flow do not add up, or if no record is excluded at full-text stage, the screening was not performed as described. This is checkable by any reader in under a minute, and we found an instance in our own seed material (Section II-G).
- **Vote counting.** Reporting that “seven of nine studies found a positive effect” treats studies of wildly different quality and size as equal votes.
- **Single-database retrieval,** which silently inherits that database’s publisher coverage.
- **Synthesising incommensurable outcomes** into an apparent consensus.

F. Checklist

- Protocol written before search.
- Queries and dates recorded verbatim.
- Two or more databases plus preprints.
- Snowballing performed and reported.
- Dual screening with an agreement statistic.
- Full-text exclusion reasons recorded.
- PRISMA flow that reconciles.
- Extraction form piloted.
- Limitations of the review distinguished from limitations of the included studies.

V. FAMILY B: DESIGN SCIENCE RESEARCH

A. Purpose and when to use it

Design science produces and evaluates an artifact, a model, method, framework, instantiation, that addresses a class of problem. Use it when the contribution is something that did not previously exist and the question is whether it works. Much of the enterprise security corpus is design science whether or not it uses the label: maturity models, threat-modeling languages, risk frameworks, testbeds and training platforms are all artifacts [36]–[39].

B. Protocol

Peppers et al.’s design-science research methodology gives the six activities that have become standard [40], and Hevner et al.’s guidelines give the evaluation discipline [41]:

- 1) **Problem identification and motivation.** State the problem class, not the instance, and justify why an artifact is the appropriate response.
- 2) **Objectives of a solution.** Define what the artifact must achieve, in terms that can be measured. This is where most security design science weakens: the objectives are stated qualitatively and the evaluation then cannot fail.

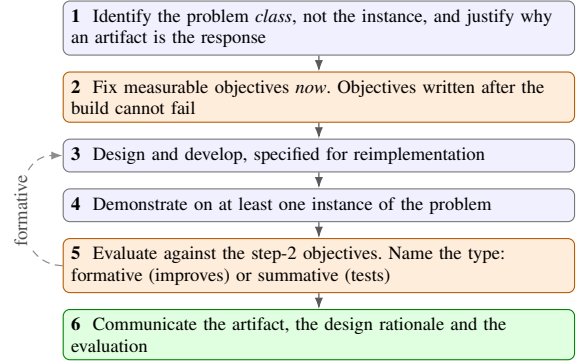


Fig. 3. Family B, after Peppers et al. [40]. The dashed edge is the formative loop, and drawing it makes the distinction that this family most often loses: an iteration from evaluation back into design improves the artifact and cannot also test it. A paper that runs only this loop has demonstrated feasibility, not effectiveness.

- 3) **Design and development.** Build the artifact and describe its structure at a level that permits reimplementaion.
- 4) **Demonstration.** Show it working on at least one instance of the problem.
- 5) **Evaluation.** Compare observed behaviour against the objectives from step 2. Distinguish *formative* evaluation, which improves the artifact, from *summative* evaluation, which tests it.
- 6) **Communication.** Report the artifact, the design rationale and the evaluation.

The protocol is illustrated in Figure 3.

C. Evaluation designs, in increasing strength

- 1) *Illustrative scenario* — the artifact is applied to a constructed example. Weakest; demonstrates feasibility only.
- 2) *Expert evaluation* — practitioners assess the artifact. Used for the CTI-SOC maturity model, evaluated by expert interviews together with a prototype [36], and for model-based dependency analysis, validated through two case studies and expert interviews [1].
- 3) *Case application in a real organisation* — as in the MARISMA-CPS risk pattern applied in a smart-hospital case [38] and the model-based security design method assessed against industrial cases [42].
- 4) *Comparative evaluation against an existing artifact* on a shared task.
- 5) *Controlled experiment* with participants or systems randomised to artifact versus baseline. Rare in this corpus, and the strongest available.

The evaluation ladder is illustrated in Figure 4.

D. What the evidence supports

Confidence: Moderate that design science is the appropriate vehicle for framework, model and platform contributions in enterprise security. **Confidence: Limited** for claims of operational effectiveness derived from design science alone, because, in our coding of the corpus (Section II-F), evaluation

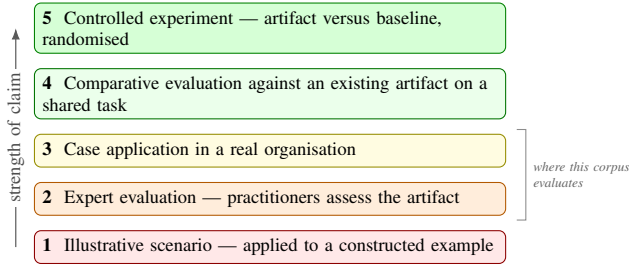


Fig. 4. Family B evaluation designs, weakest at the bottom. A claim of operational effectiveness needs rung 4 or 5; in our coding, the enterprise security corpus reviewed here evaluates mostly at rungs 2 and 3, which is why the confidence label for that claim is *Limited* rather than the label the individual papers’ care would otherwise support.

is predominantly formative, expert-based or single-case. The decision-support artifact for threat and incident managers is candid about this: iterative formative evaluation with ten professionals across three financial institutions indicated potential usefulness, and no summative evaluation was conducted [43].

E. Failure modes

Objectives written after the artifact; “evaluation” that only demonstrates; the artifact described at a level that prevents reimplementaion; expert panels drawn from the authors’ own collaborators; and the absence of any comparison to what practitioners already do, which is the true baseline.

F. Checklist

- Problem class stated.
- Measurable objectives fixed before build.
- Artifact specified for reimplementaion.
- Evaluation type named as formative or summative.
- Baseline identified.
- Threats to the evaluation’s validity stated.
- Artifact released (Section XVI-C).

VI. FAMILY C: QUALITATIVE AND SOCIO-TECHNICAL INQUIRY

A. Purpose and when to use it

Qualitative inquiry answers why practitioners act as they do, how work is actually organised, and what a technical measure is missing. Use it when the phenomenon is organisational, when the variables are not yet known, or when a quantitative result is inexplicable. The corpus shows this repeatedly: topic modeling of information-security journals combined with a Delphi study of corporate chief information security officers exposed a gap between academic emphasis and practitioner priority [44]; interviews with incident-response teams surfaced communication and collaboration failures between response and security management and yielded a security-learning model [45]; a needs assessment across five Dutch computer security incident response teams organised performance problems into organisational, team, individual and instrumental categories [46].

Security operations centres are the setting where this family has produced findings that no technical measurement reaches.

A qualitative study of matched and mismatched centres, interviewing analysts and managers within the same organisations, located the problems in the relationship between the two groups rather than in either alone [47], which is a result only obtainable by sampling both sides of a boundary. A complementary study of analyst challenges and performance metrics documents what the centre is actually measured on and what that measurement omits [48]. The methodological point generalises: where a technical metric and a practitioner account disagree, the disagreement is usually the finding.

B. Reflexive thematic analysis: the protocol

Braun and Clarke’s six phases are the most-used framework and the most-often misused [49]. The authors’ own later critical review found that published applications frequently violate the framework’s assumptions, most commonly by treating themes as things that “emerge” and by seeking inter-coder agreement in a design whose premises do not support it [50]. The phases:

- 1) **Familiarisation.** Read the whole corpus actively; write analytic notes. Transcribe your own interviews if at all possible.
- 2) **Systematic coding.** Generate codes across the entire dataset, not just the parts that interest you. Codes are short, specific and grounded in the data (escalation-blocked-by-ownership, not communication).
- 3) **Generating initial themes.** Collate codes into candidate themes. A theme is a pattern of shared meaning organised around a central concept, not a topic summary.
- 4) **Developing and reviewing themes.** Check candidates against the coded extracts and against the whole dataset. Collapse, split or discard.
- 5) **Refining, defining and naming themes.** Write a short definition for each, stating its boundary and what it excludes.
- 6) **Writing up.** The analysis is written, not reported; extracts are evidence within an argument, not illustration after it.

The protocol is illustrated in Figure 5.

C. Choosing among the qualitative designs

- **Semi-structured interviews** when you need practitioner accounts. Purposive sampling; an interview guide with open questions and planned probes; recruitment continued until additional interviews stop changing the coding. “Saturation” is the usual word for that stopping rule and it is used loosely: Saunders et al. distinguish several incompatible conceptualisations and require a study to say which one it operationalised and how it judged it reached [51]. A sample size defended only by the word itself has defended nothing. Knowles et al.’s study of the penetration-testing ecosystem interviewed 54 stakeholders and used the result to argue for standardisation of scoping, delivery and reporting [52]. Where the practitioner is a developer rather than a defender, the same

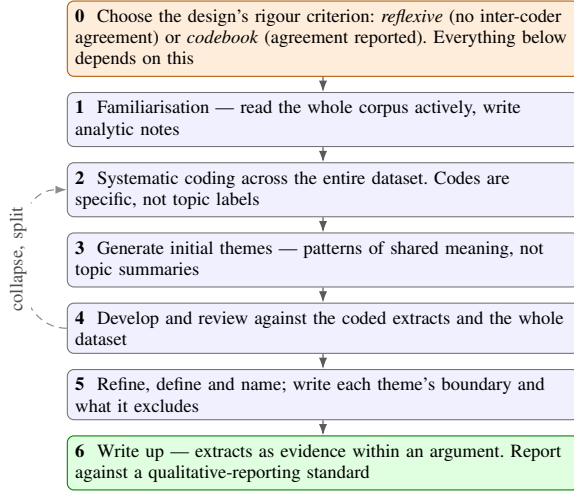


Fig. 5. Family C, following Braun and Clarke’s six phases [49]. Step 0 is not in the original and is the one this corpus most often gets wrong: the authors’ own critical review found published applications reporting an agreement statistic inside a reflexive design, whose premises do not support one [50]. The choice has to be made before coding, because it determines what counts as rigour afterwards.

design applies: Naiakshina et al. combined a programming task with qualitative interviewing to establish *why* developers store passwords insecurely, and found that the omission was usually a matter of what the task appeared to ask for rather than of knowledge [53], a mechanism no survey of developer knowledge would have surfaced.

- **Case study** when the phenomenon cannot be separated from its context. Runeson and Höst’s guidelines specify the case and unit of analysis, the multiple data sources, the chain of evidence and the reporting structure [54]; the incident-response case analysis in an Australian financial organisation is a worked example [45].
- **Cognitive task and cognitive work analysis** when the object of study is the decision itself, what the analyst attends to, what they must hold in mind, where the load falls. This produced a critical-thinking memory aid for threat and incident managers balancing operational context against investigation [43].
- **Delphi** when you need structured expert consensus on something no dataset contains. Okoli and Pawlowski’s design guidance covers panel selection, the anonymous iterative rounds and the stopping rule [55]; a zero-trust maturity assessment framework derived its critical success factors this way [56].
- **Human-factors mixed methods** when management and employee perspectives diverge. In pilot healthcare organisations, combining surveys, interviews and telemetry showed that a stronger security culture did not necessarily produce more rule-compliant behaviour, and that conflicts among rules and procedures could themselves create vulnerabilities [57].

D. Rigour and reliability

Two positions exist and a study must choose one and be consistent. In *reflexive* thematic analysis, the researcher’s

interpretation is the instrument, and inter-coder agreement is not an appropriate criterion; rigour is demonstrated through reflexivity, an audit trail and analytic depth [50]. In *codebook* or content-analytic designs, agreement is appropriate and should be reported.

Where agreement is reported, Cohen’s κ corrects observed agreement for chance:

$$\kappa = \frac{p_o - p_e}{1 - p_e} \quad (1)$$

where p_o is observed agreement and p_e is the agreement expected by chance from the marginal distributions. Landis and Koch’s interpretive bands, slight, fair, moderate, substantial, almost perfect, remain the common reference [58]. However, McHugh’s account of the statistic’s behaviour demonstrates that these bands are unreliable in skewed distributions [59]. Two properties matter in practice. First, κ is depressed when one category dominates, which is the normal situation in security coding; a high p_o with a low κ is a prevalence artifact, not necessarily poor coding. Second, κ handles exactly two coders and nominal categories. For more coders, ordinal categories or missing data, Krippendorff’s α is the appropriate measure [60]:

$$\alpha = 1 - \frac{D_o}{D_e} \quad (2)$$

with D_o the observed disagreement and D_e the disagreement expected by chance. Report the statistic, the number of coders, the proportion of the corpus double-coded, and how disagreements were resolved.

Two reporting standards exist for this family and neither is used in security research as often as it should be. The Consolidated Criteria for Reporting Qualitative Research (COREQ) is a 32-item checklist for interview and focus-group studies, organised around the research team, the study design and the analysis, and it exists because qualitative papers routinely omit the details that let a reader judge the account, who conducted the interviews, what relationship they had with participants, how many refused [61]. The Standards for Reporting Qualitative Research (SRQR) is the broader instrument, covering qualitative designs generally rather than interview studies specifically, and is derived from a synthesis of earlier standards [62]. Write against one of them from the start; both are far easier to satisfy prospectively than to retrofit, because several items concern decisions made before data collection.

E. What the evidence supports

Confidence: Moderate that organisational coordination, cognitive workload, rule conflict and temporal variation in behaviour materially affect security outcomes and are not visible to technical measurement. Self-report bias, small purposive samples, sector-specific sites and limited transferability remain the standing limitations.

F. Checklist

- Design named and its rigour criterion consistent with it.
- Sampling strategy and its rationale.

- Recruitment and refusal reported.
- Interview guide included.
- Coding procedure described.
- If agreement is claimed, statistic, coder count and double-coded proportion reported.
- Reflexivity statement.
- Ethics approval.
- Extracts attributed to distinct participants rather than repeatedly to the most articulate one.

VII. FAMILY D: SURVEY, BEHAVIOURAL AND LONGITUDINAL DESIGNS

A. Purpose and when to use it

Surveys estimate how a construct is distributed in a population and what covaries with it. Use them when the construct is latent, intention to comply, perceived threat severity, security culture, and when you can define and reach a population. Protection-motivation and institutional-governance accounts of information-security policy compliance are the recurring theoretical frames [63].

B. Protocol

- 1) **Define the population and the sampling frame separately.** The population is who the claim is about; the frame is who could actually be sampled. The difference between them is the coverage error, and it must be stated.
- 2) **Operationalise constructs** using previously validated scales wherever they exist, citing the source. New items require a pilot and a validation step.
- 3) **Determine sample size from the intended analysis,** not from convenience. Cohen's power primer gives the conventional effect-size benchmarks and the relationship between α , power, effect size and n [64].
- 4) **Pilot** with 10–30 respondents from the target population; check item comprehension and completion time.
- 5) **Administer**, recording the invitation count, the response rate and the completion rate. Test for non-response bias by comparing early and late respondents.
- 6) **Assess the measurement model before the structural model.** For PLS-SEM, Hair et al. specify the sequence: indicator reliability, internal consistency, convergent validity (average variance extracted), discriminant validity (heterotrait–monotrait ratio), and only then path coefficients, R^2 , f^2 and bootstrapped significance [65].
- 7) **Report** the full measurement model, not only the path diagram. Where the survey was administered over the web, which in enterprise security it almost always is, report it against CHERRIES, which asks for the things a web survey can silently omit: whether the sample was open or closed, how the invitation was delivered, whether completeness checks or adaptive questioning were used, and how duplicate submissions were prevented [66]. It also fixes the ambiguity that makes web-survey response rates incomparable, by distinguishing the view rate, the participation rate and the completion rate rather than reporting one number called “the response rate”.

The protocol is illustrated in Figure 6.

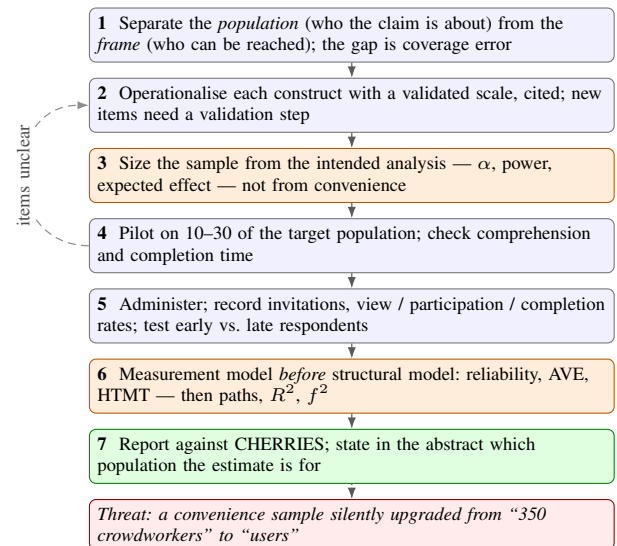


Fig. 6. Family D. Step 6 is ordered, not a list: a path coefficient computed on a measurement model that has not been shown to be reliable and discriminant is a number about nothing. Step 3 is a gate because a survey underpowered for its intended test cannot be repaired after collection. The pilot feeds back into operationalisation, which is the only cheap place to fix a misread item.

C. The generalisation problem, and what to do about it

Security and privacy survey research relies heavily on convenience samples, and the question of whether those results transfer has been tested directly. Redmiles et al. compared results obtained from a census-representative panel, from a crowdworker platform and from a web panel, and found that the answer depends on the measure: some estimates transfer acceptably and others do not, in ways that are predictable from the demographics involved [67]. The practical consequence is not that convenience samples are unusable. It is that a paper using one must state which population its estimate is for, and must not silently upgrade “350 crowdworkers” into “users”.

D. Longitudinal and within-person designs

Cross-sectional surveys identify between-person patterns at one point in time. They cannot identify within-person patterns, even though most behavioural theory in security is stated in within-person terms, that a *given* employee complies less when they neutralise. Cram et al. make this argument and test it, applying an idiographic approach to neutralisation theory through a four-week experience-sampling study, and finding that cybersecurity behaviour varies within the same person over time [20]. Where the theory is within-person, a one-time survey is the wrong instrument regardless of its sample size.

Experience sampling in practice: recruit a smaller panel; prompt several times per week at semi-random times; keep each prompt under two minutes; expect and report attrition; analyse with multilevel models that separate within-person from between-person variance.

E. Structured expert elicitation: the Delphi design

Some questions have no population to sample. “What are the most effective defences against social engineering in this

sector?” cannot be answered by asking a representative sample of employees, because most of them have no basis for an answer; it can only be put to people who have worked the problem. A one-shot survey of experts is the weak version of this, because it records opinions without letting them meet each other. Delphi is the structured version: successive anonymous rounds, each fed by the aggregated responses of the last, continued until the panel converges or stably fails to.

Campbell’s study of social-engineering countermeasures is a usable model of the design in this setting: 20 information-security practitioners, three rounds, with each round condensing the previous round’s items and returning them for re-rating, producing three prioritised problem areas and a set of countermeasures the panel converged on [68]. The elements that make such a study reportable are the ones to copy: the recruitment criterion that defines what “expert” meant here, the panel size and its attrition between rounds, the stopping rule fixed in advance, and the aggregation statistic used to decide that consensus had been reached. Anonymity between panellists is the point of the design, not an administrative detail, it is what stops the most senior participant from setting the answer in round one.

Delphi licenses a claim about *expert consensus* and nothing stronger. It does not establish that the countermeasures work; it establishes that practitioners with stated qualifications agreed that they do. Papers in this family fail most often by reporting the consensus as though it were an effectiveness result.

F. What the evidence supports

Confidence: Moderate for survey designs as instruments for latent organisational constructs, conditional on measurement-model reporting. **Confidence: Limited** for the within-person finding, which rests on a single four-week study, though the methodological argument for the design is independent of that study’s results.

G. Checklist

- Population and frame distinguished.
- Scales cited or validated.
- Power analysis reported.
- Pilot conducted.
- View, participation and completion rates reported separately.
- Non-response bias tested.
- Measurement model reported in full before structural results.
- The population the estimate generalises to stated in the abstract.
- CHERRIES items addressed for a web-administered instrument. For a Delphi study: the expertise criterion, the panel size and per-round attrition, the pre-specified stopping rule, and the consensus statistic.

VIII. FAMILY E: THREAT MODELING, ATTACK GRAPHS AND QUANTITATIVE RISK

A. Purpose and when to use it

Threat modeling connects technical weaknesses to enterprise risk decisions. Use it when the question concerns which

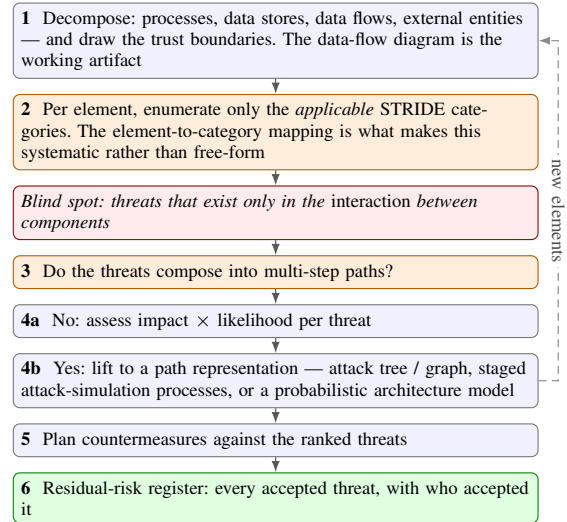


Fig. 7. Family E. Step 2 is a gate because free-form threat brainstorming is not STRIDE; the systematicity lives entirely in the element-to-category mapping. Step 3 is the decision this family most often skips: enumeration answers “what can go wrong here”, and only a path representation answers “what can an adversary chain”. A model refined at 4b usually exposes elements missing from the data-flow diagram, so the loop back to step 1 is expected, not a sign of a bad first pass.

attack paths exist in a system, what they would cost an attacker, and where a control would be most effective. We begin with Spoofing, Tampering, Repudiation, Information disclosure, Denial of service and Elevation of privilege (STRIDE), the most widely used enumeration.

B. STRIDE: the protocol

- 1) **Decompose** the system into processes, data stores, data flows, external entities and trust boundaries. A data-flow diagram is the working artifact.
- 2) **Enumerate** threats per element against the six categories: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege. Not every category applies to every element type, and the element-to-category mapping is what makes the method systematic rather than free-form.
- 3) **Assess** each threat for impact and likelihood.
- 4) **Plan countermeasures** and record the residual risk of each accepted threat.

The protocol is illustrated in Figure 7.

Applied to a synchrophasor cyber-physical testbed with data-flow diagrams, STRIDE was characterised as lightweight and effective for component-level analysis, with the explicit caveat that threats arising only from interactions *between* components can be missed [69]. A container-ecosystem study used the same method across repositories, image registries, containers and hosts, and then surveyed countermeasure strengths and weaknesses, which is the correct pairing, since threat enumeration without mitigation analysis produces a list nobody can act on [4].

C. Risk-centric and graph-based extensions

STRIDE enumerates; it does not compose. Multi-step attacks require a representation with paths.

- **Process for Attack Simulation and Threat Analysis** integrates threat modeling with the development lifecycle across seven stages and aligns countermeasures with business impact [70].
- **Integrated software- and attack-centric modeling** combines system models, component models, attack trees, attack graphs and Common Vulnerability Scoring System (CVSS) scoring; a railway communication network is the worked case [71].
- **Attack-graph meta-languages** formalise attack-step dependencies so that attack sequences and time-to-compromise can be simulated rather than enumerated by hand [37].
- **Probabilistic architecture models.** CySeMoL estimates the probability of successful attack in an enterprise architecture by probabilistic inference, and was validated by comparison against security professionals' judgement and case studies [72].

D. Reducing dependence on expert construction

The standing weakness of this family is that the model is built by hand by an expert, so it scales poorly and inherits that expert's assumptions. Two directions address it. Malcoda gathers data automatically from deployed security products, constructs a Bayesian directed acyclic graph and computes risk probabilities per asset and vulnerability; in a virtual enterprise network it completed assessments quickly, produced probabilities that tracked intrusion-detection alerts, and had computational complexity no greater than comparable models [73]. Dynamic multilevel risk modeling pursues the same goal for large distributed systems using security metrics, though the specific datasets and validation environment were not reported, which is itself the reason we label it lower [74]. Security assurance metrics work supplies the measurement layer these models need [75].

E. Decision-theoretic and network-analytic extensions

Two further quantitative treatments answer questions that enumeration and probability alone do not.

Decision-theoretic investment modeling asks not which paths exist but how much to spend and where. Formulating enterprise resilience through expected utility, with x the defensive investment and y the recovery investment, gives an objective of the form

$$EU(x, y) = (1 - p(x)) U(W - x - y) + p(x) U(W - x - y - L(y)) \quad (3)$$

where $p(x)$ is the breach probability under defensive spend x , $L(y)$ the residual loss after recovery spend y , W the initial endowment and U a utility function encoding the organisation's risk attitude. An expected-resilience framework built on this basis models defence and recovery investment jointly and derives allocation strategies [76]. The methodological

requirement is the same as for any model in this family: state where $p(\cdot)$, $L(\cdot)$ and the risk-attitude parameter come from, and run sensitivity analysis over them, because the optimum is a function of assumptions rather than of measurements.

Network analysis of technique taxonomies treats a framework such as MITRE ATT&CK as a graph and asks which techniques are structurally central to attack paths. Applying semantic network analysis to enterprise ATT&CK techniques identifies the ones that recur across pathways, credential access and valid-account abuse being the usual result, and thereby offers a defensible ordering for control prioritisation [77]. Betweenness centrality is the standard instrument,

$$C_B(v) = \sum_{s \neq v \neq t \in V} \frac{\sigma_{st}(v)}{\sigma_{st}} \quad (4)$$

with σ_{st} the number of shortest paths from s to t and $\sigma_{st}(v)$ the number of those passing through v . Two cautions apply. The centrality of a technique in the taxonomy reflects how the taxonomy was written, not how often adversaries use the technique; and a graph built from documented procedures inherits the reporting bias of the threat intelligence that produced them. Weighting edges by observed incident frequency, where such data exist, converts a structural claim into an empirical one.

A historical benchmark is worth keeping in view. Ortalo et al. monitored a large operational system for nearly two years, modelling privilege graphs and estimating the effort required of an attacker [78]. Longitudinal operational measurement of this kind remains uncommon, and it is what most modern risk models are implicitly claiming to approximate.

F. What the evidence supports

Confidence: Moderate that threat modeling and probabilistic or graph-based analysis usefully structure enterprise risk. Confidence in generalisation is reduced by case-specific assumptions, dependence on expert input, limited validation against real incidents, and threat conditions that change faster than models are rebuilt.

G. Failure modes

Treating a CVSS base score as a risk estimate; models whose parameters are elicited from the same experts who then validate them; attack graphs whose state space is pruned in undocumented ways; and probability outputs reported without sensitivity analysis over the inputs that are least well known.

H. Checklist

- System decomposition and trust boundaries shown.
- Method named and its scope limit stated.
- Parameter sources identified and separated from validators.
- Sensitivity analysis over uncertain inputs.
- Validation against something other than the authors' own judgement.
- Residual risk recorded for accepted threats.

IX. FAMILY F: SIMULATION AND MODEL-BASED ANALYSIS

A. Purpose and when to use it

Simulation is the method of choice where direct experimentation would disrupt a critical process or require exercising a dangerous capability. Use it to explore cascading consequences, to run sensitivity analyses that no live system would tolerate, and to compare defensive configurations at a scale that field measurement cannot reach.

B. The main formalisms

- **Stochastic Petri nets** model the interaction between adversary and defence as concurrent stochastic processes, and support optimisation of design parameters. Applied to a modernised electrical grid, this identified intrusion-detection intervals and redundancy levels that maximise mean time to failure [79].
- **System dynamics with sensitivity analysis** measures how covariances among observed variables change before and after an intervention. Experiments using IEEE 14-bus and 300-bus grid models together with the Tennessee Eastman chemical process demonstrated efficiency, scalability and cross-sector applicability within the tested scenarios [80].
- **Integrated cyber-physical simulation with attacker-defender games.** The SURE platform combines cyber and physical models, attack models, operational scenarios and game-theoretic reasoning, applied to smart transportation including traffic-signal tampering, resilient sensor selection and denial of service [2].
- **Dependency modeling for cascade analysis.** Model-based cybersecurity analysis partitions cyber and cyber-physical functional dependencies to model cascading effects, instantiated on power-grid models and a municipal grid and checked against expert interviews [1].

C. Protocol

- 1) State the question as a comparison between configurations or a sensitivity over parameters. Simulation answers “what changes if” well and “what is true” badly.
- 2) Specify the model: state variables, transitions, stochastic assumptions, time semantics.
- 3) Identify every parameter and its source. Separate measured parameters, estimated parameters and assumed parameters, and label them as such in the paper.
- 4) Verify the implementation (does it compute the model) before validating the model (does the model correspond to reality). These are different activities and both are needed.
- 5) Establish run length and replication count from the variance of the output, and report confidence intervals over replications rather than single runs.
- 6) Run sensitivity analysis over the assumed parameters. If a conclusion inverts within the plausible range of an assumed parameter, that is the finding.
- 7) Validate against something external: an operational incident record, expert judgement, or a physical testbed.

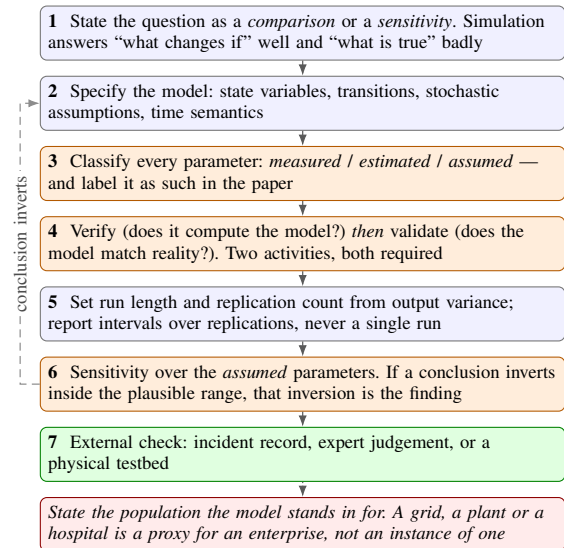


Fig. 8. Family F. Three of the seven steps are gates, which is the distinguishing feature of this family: a simulation always produces numbers, so the discipline has to come from the protocol rather than from the possibility of failure. Step 3 is the one most often omitted, an unlabelled parameter table lets a reader assume every value was measured, and it is what makes step 6 meaningful, since sensitivity analysis is only informative over the parameters that were assumed.

The protocol is illustrated in Figure 8.

D. What the evidence supports

Confidence: Moderate for the methodological usefulness of simulation in this setting. **Confidence: Limited** for any prediction outside the modelled infrastructure or the modelled scenario set. Model fidelity is the binding constraint: simulated attacks, dependencies and operational responses need not reproduce the behaviour of a real organisation, whose responses are made by people under time pressure. The studies here examined grids, transport, chemical process and a hospital, which are proxies for, not instances of, a general enterprise population.

E. Checklist

- Model specification complete enough to reimplement.
- Parameters classified by source.
- Verification distinct from validation.
- Replication count justified.
- Confidence intervals over replications.
- Sensitivity analysis on assumed parameters.
- External validation attempt.
- Explicit statement of the population the model stands in for.

X. FAMILY G: MACHINE-LEARNING EXPERIMENTATION

A. Purpose and when to use it

This is the dominant methodology for detection research and the one with the most thoroughly documented pathologies. Use it when the question is whether a model can discriminate a class of events, under stated conditions, at an operating point that is usable.

B. The baseline protocol

- 1) **Define the operational task** before choosing data: what is detected, at what latency, with what consequence for a false positive and for a false negative. The consequence asymmetry determines the metric and the operating point, so it cannot be decided afterwards.
- 2) **Select data** and state its provenance, collection period, labelling procedure and label quality. Benchmarks in wide use here include KDD 99, NSL-KDD, CIC-IDS2017, CIC-IDS2018 and UNSW-NB15; each has documented artifacts, and using one is a decision to be justified rather than a default. CIC-IDS2017 is the instructive case, because two independent re-examinations found defects in it and both found that the defects change results. Engelen et al. traced errors to the traffic generation, the attack execution and the labelling, and reported that correcting them alters the measured detection performance [81]; Lanvin et al. quantified the difference the corrections make and found it substantial enough to affect comparisons between detectors [82]. Before adopting any benchmark, search for work that has audited it, and state which version or corrected release you used.
- 3) **Split before you preprocess.** Fit every transformation, normalisation, feature selection, encoding, dimensionality reduction, on the training partition only, then apply to validation and test. Fitting on the full dataset leaks test information into training and inflates every downstream number.
- 4) **Handle class imbalance explicitly, and only inside training folds.** Oversampling applied before the split fabricates near-duplicates of test points into the training set. This is the most common single defect in the detection literature.
- 5) **Choose the split to match the deployment question.** Random k -fold answers “can the model separate these classes”. It does not answer “will the model work next month”, because random splitting places future samples in the training set. For that question the split must be temporal (Section X-D).
- 6) **Tune hyperparameters on a validation partition,** never on test, and report the search space and budget.
- 7) **Report the full confusion matrix** plus precision, recall, F_1 , and a threshold-free curve. Report training and inference cost, which determine deployability.
- 8) **Compare against a meaningful baseline:** a simple model, and where possible the rule or heuristic actually in production.
- 9) **Repeat with different seeds** and report variance. A single-run difference of half a point is not a result.

The protocol is illustrated in Figure 9.

C. Metrics, and why accuracy is the wrong one

With TP , FP , TN , FN from the confusion matrix:

$$\text{Precision} = \frac{TP}{TP + FP}, \quad \text{Recall} = \frac{TP}{TP + FN} \quad (5)$$

$$F_1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}} \quad (6)$$

Benign traffic vastly outnumbers attack traffic, so accuracy is dominated by the majority class and a trivial always-benign classifier scores well. The deeper problem is the base-rate fallacy, stated for intrusion detection by Axelsson: because the prior probability of an intrusion in any given event is extremely small, the quantity an analyst actually experiences is the Bayesian detection rate

$$P(I | A) = \frac{P(A | I) P(I)}{P(A | I) P(I) + P(A | \neg I) P(\neg I)} \quad (7)$$

which remains low even for a detector with an excellent true-positive rate, unless the false-alarm rate $P(A | \neg I)$ is driven extraordinarily low [83]. A paper reporting 99% recall without reporting the false-alarm rate at the deployed base rate has not addressed the question an operator has. Sommer and Paxson’s analysis of why machine learning is harder for intrusion detection than for other domains, the cost asymmetry, the semantic gap between an anomaly and an attack, the difficulty of obtaining ground truth, remains the reference for framing this [84].

Where the deployment cares about ranking under heavy imbalance, precision–recall curves are more informative than receiver-operating-characteristic curves, because the latter’s false-positive-rate axis is dominated by the large negative class and compresses exactly the region of interest.

D. Temporal bias, spatial bias and drift

Two biases invalidate a large fraction of published detection results. *Temporal bias* occurs when training data contains samples that post-date test samples. *Spatial bias* occurs when the ratio of malicious to benign samples in the test set does not correspond to any realistic deployment. TESSERACT formalised both, gave constraints that a sound evaluation must satisfy, and introduced a time-aware metric so that classifiers can be compared over a deployment period rather than at a point [85]; the extended treatment develops the framework further [86]. Any study whose claim concerns future performance owes the reader a temporally consistent split.

Concept drift is the underlying phenomenon: the joint distribution of features and labels changes over time, so a model degrades after deployment. The general adaptation literature classifies drift and the responses to it [87]. In security specifically, conformal-evaluation approaches identify samples that a deployed classifier should reject rather than classify; the Transcend line of work revisited these methods, analysed their statistical basis and reported the conditions under which they hold [88].

Studying drift requires a dataset with a usable time axis, which most security benchmarks do not have, a single snapshot cannot exhibit drift no matter how it is split. Purpose-built longitudinal benchmarks are the enabling instrument here: LAMDA is an Android malware benchmark assembled specifically so that concept drift can be measured, with samples spanning multiple years and timestamps that support temporally consistent splitting [89]. When designing a drift study,

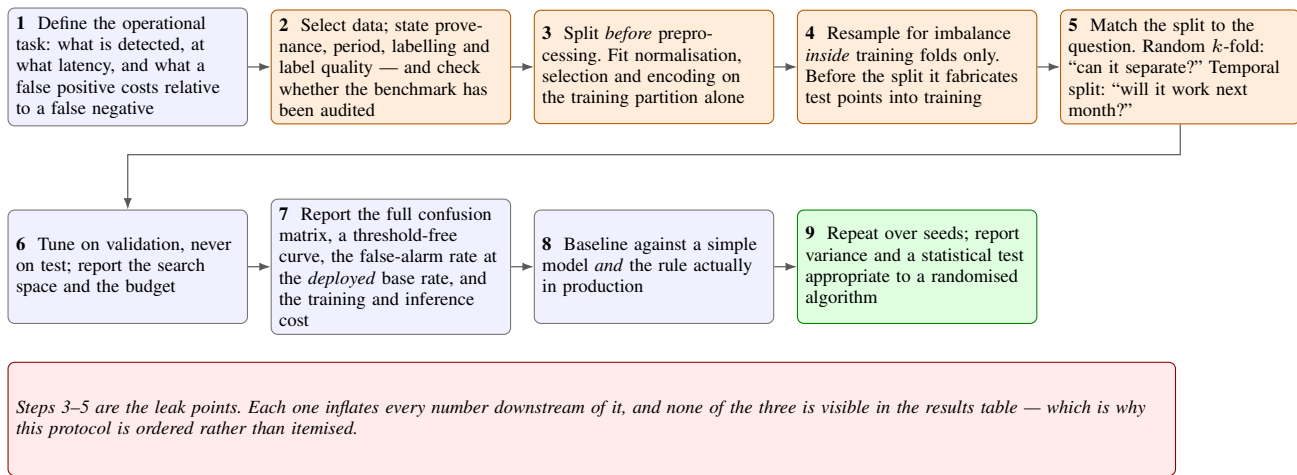


Fig. 9. Family G. The order matters more than the content. Steps 3–5 concern only where a boundary is drawn in the data, cost nothing to get right, and are the defects most often found in published detection work; a paper that fits a scaler on the whole dataset before splitting reports numbers that no amount of later rigour repairs. Step 5 is a gate rather than a step because it is not a methodological preference: random and temporal splits answer different questions, and only one of them is the question a deployment asks.

choose the dataset for its time coverage first; no evaluation protocol can recover a time axis the data does not carry.

E. Pitfalls with names

Arp et al. catalogue ten recurring pitfalls in machine learning for computer security, demonstrate their prevalence in published work, and quantify how much reported performance they account for [90]. They include sampling bias, label inaccuracy, data snooping, spurious correlations, biased parameter selection, inappropriate baselines, inappropriate performance measures, base-rate neglect, lab-only evaluation and inappropriate threat models. The corresponding earlier statement for malware experiments specifically, correct dataset construction, correct handling of goodwill, transparency about what was executed, is Rossow et al.’s prudent practices [91]. Reading both before designing an experiment is a better use of a week than any amount of additional tuning.

Two further concerns apply when the model is itself the object of attack. Adversarial machine learning has a decade of accumulated methodology on how evaluations against an adaptive adversary must be constructed to be meaningful [92]. And where a paper claims explainability, the explanation method itself needs evaluating: Warnecke et al. define criteria, descriptive accuracy, sparsity, stability, efficiency, robustness, and apply them to explanation methods in security settings [93]. Explainable-artificial-intelligence intrusion-detection work is evaluated against those criteria rather than against the plausibility of the produced explanation [94].

F. Comparing randomised systems: the statistics step 9 requires

Step 9 says “report variance”. What it means in practice is that a comparison between two randomised procedures is a statistical question and has to be answered with a statistical test, not by comparing two means. Arcuri and Briand set out the practical version of this for software engineering:

run enough repetitions, use a non-parametric test, the Mann–Whitney U test, because the outcome distributions are typically neither normal nor equally dispersed, report a standardised effect size such as the Vargha–Delaney $\hat{A}_{12}$ alongside the p -value, and correct for multiple comparisons when several configurations are compared at once [95]. All four apply unchanged to a detector compared across seeds, and the effect size is the one most often missing: with enough repetitions any difference becomes significant, and only the effect size says whether it matters.

Klees et al. make the same argument for fuzzing and make it concretely, by re-running published evaluations under a corrected protocol. Their findings, that results depend heavily on the seed corpus, that the timeout chosen changes which tool wins, that crash de-duplication by stack hash inflates bug counts, and that most published comparisons used too few trials to support their conclusion, are specific to fuzzing, but the underlying failure is not [96]. It is the practice of reporting one run of a stochastic process as though it were a measurement. Where a security experiment involves any randomised component, seed, initialisation, sampling, scheduling, or an attack generator, the same three requirements hold: multiple trials, a test that matches the distribution, and an effect size.

G. What the evidence supports

Confidence: Strong that comparative experimentation with transparent preprocessing, splitting and metric reporting is the appropriate design for detection questions. **Confidence: Conflicting** for any claim that one algorithm family dominates in enterprise deployment; Section XVII analyses this directly. **Confidence: Limited** for transferring any benchmark result to a live enterprise network, because, in our coding, the corpus evaluates almost entirely on benchmark, simulated or laboratory data rather than on continuously collected enterprise populations [97]–[102].

H. Checklist

- Operational task and cost asymmetry stated.
- Data provenance and labelling described.
- Preprocessing fitted inside the training partition only.
- Resampling inside folds only.
- Split type justified against the deployment question.
- Temporal consistency where the claim is about the future.
- Hyperparameter search space and budget reported.
- Full confusion matrix.
- False-alarm rate at a realistic base rate.
- Training and inference cost.
- Baseline including the incumbent.
- Multiple seeds with a non-parametric test and an effect size.
- Code and configuration released.

This family has no reporting standard of its own, which is part of why the same defects recur. The nearest usable instrument comes from clinical prediction modelling: the Transparent Reporting of a multivariable prediction model for Individual Prognosis Or Diagnosis (TRIPOD) is a 22-item checklist for reporting a multivariable prediction model, and its items map onto detection research almost directly, how participants (here, samples) were selected, how predictors were defined and measured, how missing data were handled, how the model was specified, how performance was assessed, and what happened at validation [103]. It is not a security instrument and its vocabulary has to be translated, but a detection paper that can answer all 22 items has answered the questions that make a model assessable.

XI. FAMILY H: EVALUATING LANGUAGE-MODEL AND AGENTIC SYSTEMS

A. Why this needs its own methodology

Language-model-based systems break several assumptions the previous section relies on. The training corpus is unknown, so a benchmark may already be inside it. The output is free text, so scoring requires a judge. The system is often agentic, so behaviour depends on the environment and on the number of attempts allowed. Each of these creates a distinct validity threat, and a synthesis of pitfalls in language-model security research documents how frequently they go unaddressed [104].

B. Contamination and construct validity

Benchmark contamination is the check to run before any other. If a public benchmark predates the model, a strong score may measure recall rather than capability. Mitigations: construct or hold out tasks after the model’s cutoff; perturb tasks so that memorised solutions do not transfer; report the model version and date; and treat public-benchmark results as an upper bound. A related failure appears in log analysis, where passive content in the context window can steer the analysis, context contamination that a conventional accuracy measure does not detect [105].

C. Language models as judges

Using a model to score another model’s output is now routine and needs its own validity argument. A systematisation of security concerns in the judge setting catalogues the attack surface and the failure modes [106]. More pointedly, a large-scale evaluation of judge models found high reliability, the judge agrees with itself, without corresponding validity, meaning consistent scores that do not track the quality being claimed [107]. Reliability is therefore not evidence of validity, and reporting only agreement between judge runs is not an evaluation. Minimum practice: calibrate the judge against human labels on a sample, report that agreement with a chance-corrected statistic (Equation (1) or Equation (2)), randomise presentation order, and check for position and verbosity effects.

D. Agentic security systems

Benchmarking agents that act, scanning, exploiting, remediating, is harder again, because the environment is part of the measurement and success is path-dependent. A direct treatment of why this is hard identifies the ways an agent benchmark can flatter its subject [108]. Concrete studies show what a careful design looks like: automated web penetration testing evaluated against a defined capability ladder [109]; and a comparison of artificial-intelligence agents against cybersecurity professionals in real-world penetration testing, which is the design that answers the question practitioners actually ask [110]. Where the output is a detection artifact rather than an action, the artifact can be evaluated on its own terms, as in the assessment of model-generated detection rules [111]. Systematic review of algorithmic red-teaming methodology organises this emerging space [27].

E. Protocol additions

Beyond the machine-learning checklist: state the model, version and access date; state the sampling temperature and the number of attempts permitted per task, and report pass-at- k rather than best-of- n presented as a single attempt; hold out a contamination-controlled task set; if a judge is used, report its calibration against human labels; describe the environment as precisely as a testbed paper would; and report cost per task, because an agent that succeeds at arbitrary expense has not solved an operational problem.

The protocol is illustrated in Figure 10.

F. What the evidence supports

Confidence: Moderate that contamination control, judge calibration and environment specification are necessary for a defensible claim in this family. **Confidence: Limited** for any current claim about operational capability of agentic security systems, because the evaluation methodology is younger than the systems it measures.

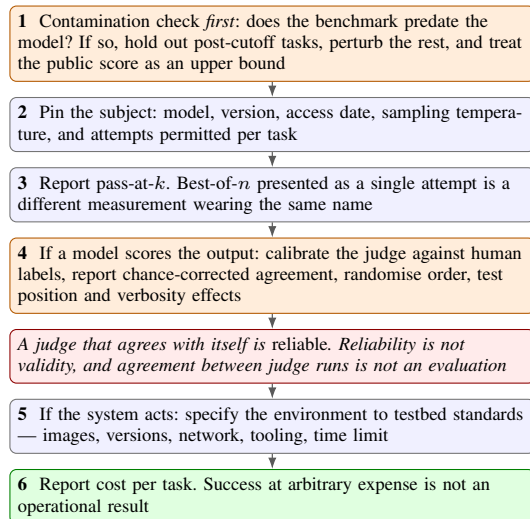


Fig. 10. Family H, as additions to the Family G protocol rather than a replacement for it. Step 1 is first because it is disqualifying: if the benchmark is in the training corpus, nothing measured afterwards is about capability. Steps 4 and 6 are the two that most often go unreported, and they fail in opposite directions, an uncalibrated judge makes a result look better than it is, while an unreported cost makes an unusable system look deployable.

G. Checklist

- Model, version and access date reported.
- Sampling temperature and attempts permitted per task stated.
- pass-at- k reported, not best-of- n presented as a single attempt.
- Contamination check run first; public-benchmark scores treated as upper bounds.
- Judge calibrated against human labels, with a chance-corrected agreement statistic.
- Presentation order randomised; position and verbosity effects tested.
- Environment specified to testbed standards (Section XIII).
- Cost per task reported.

XII. FAMILY I: MEASUREMENT, TELEMETRY AND DETECTION EFFICACY

A. Purpose and when to use it

This family asks what is observable at all. It precedes detection research logically: a detector cannot find what the telemetry does not record, and a large part of the apparent gap between laboratory and production performance lives here rather than in the model.

B. Instruments and findings

Logging is the substrate. A measurement of the detection efficacy of modern security logging standards asks what fraction of adversary behaviour the standards' recommended event sets actually make visible [112], which is the right question and one rarely asked before a detector is proposed.

Endpoint detection and response products are evaluated publicly through adversary-emulation exercises, and those results can themselves be analysed as data. A study decoding the

MITRE Engenuity ATT&CK Enterprise evaluation examined endpoint-detection performance across participants and drew out what the published results do and do not establish [113]. Reading a vendor evaluation as a measurement instrument, with its own construct validity, is a transferable methodological move.

Detector evaluation is also sensitive to how the evaluation set is constructed. For graph-based lateral-movement detection, an analysis of fair and realistic performance evaluation shows how the choice of graph, of anomaly injection and of base rate determines the reported result [114]. The same lesson appears in industrial intrusion detection, where a systematisation of evaluation practice found the field's comparisons hard to interpret for want of shared protocol [26].

Where the behaviour to be measured is the adversary's rather than the defender's, a honeypot is the instrument, and its configuration is not a deployment detail but the independent variable. Lupia et al. exposed an industrial-control honeynet emulating operational-technology devices to the Internet for three months and analysed the resulting interactions along three axes, level of interaction, origin, and interaction or attack pattern, reporting how configuration choices affect both the attractiveness of the honeynet and the behaviour it captures [115]. That is the methodological finding worth carrying: a honeypot measurement is conditional on the bait, so a paper must report the emulated device set, the exposure period and the network placement before any frequency it reports can be interpreted.

Threat-intelligence quality is the analogous measurement problem on the intelligence side: what is in a feed, how timely is it, and does it support the decisions it is bought for [116], [117]. Comparative analysis of six incident-response intelligence formats identified 18 core concepts and concluded that organisations may reasonably combine formats by use case [118].

C. Protocol

- 1) Define the observable of interest as a behaviour, not as a product feature.
- 2) Establish ground truth independently of the system being measured, emulation with a known plan, an injected campaign, or a labelled incident record.
- 3) Measure coverage first (what fraction of the behaviour appears in telemetry at all), then efficacy (what fraction of what appears is detected).
- 4) Report the configuration exactly: agent versions, rule sets, log sources enabled, retention.
- 5) Separate detection from alerting from response; a behaviour can be logged, detected, and still never reach an analyst.
- 6) Report against Strengthening the Reporting of Observational Studies in Epidemiology (STROBE). Everything in this family is an observational study, and STROBE is the reporting standard for one: it asks for the design, the setting and the dates, the eligibility criteria and how participants, here, hosts, sessions or events, were selected, how each variable was measured, how much

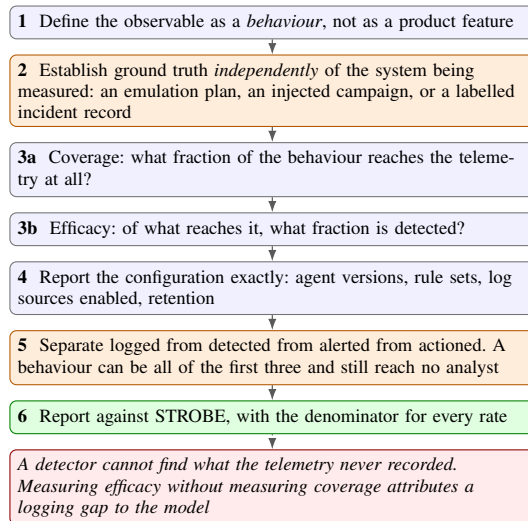


Fig. 11. Family I. The ordering of 3a before 3b is the whole point of the family: coverage and efficacy are different quantities with different denominators, and a study that reports only the second cannot tell a weak detector from an absent log source. Step 2 is a gate because ground truth derived from the system under measurement makes every subsequent number circular.

data were missing, and what the study cannot rule out [119]. Its items translate to telemetry work with almost no adaptation, and it is the instrument that stops a measurement paper from reporting a number without its denominator.

The protocol is illustrated in Figure 11.

D. Measuring consequences: the event-study design

Telemetry measures what happened inside the system. A second measurement question, what the incident cost, cannot be answered from telemetry at all, and has its own established design. The event study, borrowed from financial economics, takes a set of publicly dated events, estimates each firm's normal return from a pre-event window, and tests whether the return in a narrow window around the announcement departs from it. Campbell et al. applied this to publicly announced information-security breaches, using stock-market reaction as the measured consequence [120].

The design is worth knowing because it answers a question researchers frequently assert rather than measure, and because its constraints are instructive. It requires publicly traded firms, publicly dated announcements, and an event window short enough that no other material news falls inside it; it measures the market's expectation of cost, not the cost; and it inherits a selection problem, since breaches that are never announced are never in the sample. Any modern replication has a further difficulty: mandatory-disclosure regimes have changed both which breaches are announced and how quickly, so the sampling frame is not comparable across regulatory periods. State the frame and the window, and claim the expectation rather than the cost.

E. What the evidence supports

Confidence: Moderate that telemetry coverage is a first-order determinant of detection outcomes and is under-measured relative to model performance.

F. Checklist

- Observable defined as a behaviour, not a product feature.
- Ground truth established independently of the system measured.
- Coverage measured before efficacy, each with its denominator.
- Exact configuration reported: agent versions, rule sets, log sources, retention.
- Logged, detected, alerted and actioned separated.
- Reported against STROBE.
- For a honeypot: emulated device set, exposure period and network placement stated.

XIII. FAMILY J: TESTBEDS, CYBER RANGES AND ADVERSARY EMULATION

A. Purpose and when to use it

Experimental infrastructure is what makes a security experiment both safe and repeatable. Use it whenever the experiment involves executing attacks, when production access is impossible, or when a result must be reproducible by someone else.

B. The design space

A systematic treatment of cyber ranges and security testbeds organises the space by scenario, function, tool and architecture, and remains the reference map [22]. Recent work moves along three axes:

- **Reproducibility.** The Gotham testbed provides a reproducible environment for security experiments and dataset generation, so that a dataset carries its generating configuration with it [121]. Container-native testbeds pursue the same goal for general cybersecurity experimentation [122].
- **Scale and federation.** Federating testbeds across institutions addresses the topology and heterogeneity that a single laboratory cannot provide [123].
- **Scenario generation.** Building exercise scenarios by hand is the dominant cost in range operation, and automated scenario generation targets exactly that [124]; the cyber-range design framework integrates architecture and lifecycle with educational theory and addresses preparation cost, assessment weakness and reuse [39].

C. Adversary emulation as a measurement instrument

An emulation plan, an ordered sequence of adversary behaviours mapped to a common technique taxonomy, turns red teaming from a demonstration into a repeatable measurement. The plan is written first, executed identically across configurations, and scored against what the defensive stack produced. This is what makes the results of endpoint evaluations comparable at all [113], and it is the mechanism by which a range exercise yields data rather than an anecdote.

Penetration testing as a research method needs the same discipline. A review of penetration testing research covers tools, vulnerability classes and automation trends [23], and a mixed-method audit of a distributed firewall shows the reporting form: scanning plus testing, severity classification, and a risk report that a defender can act on [125]. The stakeholder study of the assessment ecosystem is the counterweight, documenting ambiguity in scoping and delivery that undermines comparability across engagements [52].

D. Studying real adversaries in controlled infrastructure

Emulation substitutes a researcher for the adversary, which bounds what it can establish: it measures the defensive stack's response to behaviours the researcher chose. A distinct design keeps the infrastructure under the researcher's control but lets real offenders supply the behaviour. Riccardi et al. describe the construction of an Access-as-a-Service platform modelled on illicit marketplaces, instrumented with manipulable market signals and a honeypot back end, so that offender target selection and subsequent actions can be observed and the influence of those signals assessed [126]. The paper is published as an experimental design put to the community for critique before the run, which is itself the practice this family should adopt more widely.

Designs of this kind buy ecological validity at a real price, and the price is ethical rather than technical. The researcher operates infrastructure that facilitates offending, cannot obtain consent from the population under study, and must decide in advance what to do about data on third-party victims. Anyone contemplating one should settle the containment boundary, the data-minimisation rule and the institutional and legal approvals before building anything (Section XVI-E), and should expect those constraints, not the engineering, to determine what the study can observe.

E. Protocol

- 1) Specify the environment as code. A testbed described in prose is not reproducible.
- 2) State the fidelity claim: which properties of the real environment the testbed reproduces, and, more importantly, which it does not.
- 3) Isolate. Document the containment boundary and how live-network egress is prevented.
- 4) Write the emulation plan before running it, mapped to a technique taxonomy.
- 5) Instrument the environment independently of the systems under test.
- 6) Publish the configuration, the plan and the resulting data together.

The protocol is illustrated in Figure 12.

F. What the evidence supports

Confidence: Moderate that ranges and testbeds are effective research environments for controlled security experimentation and training. **Confidence: Limited** for transferring a testbed result to production, because fidelity claims are seldom stated in falsifiable terms.

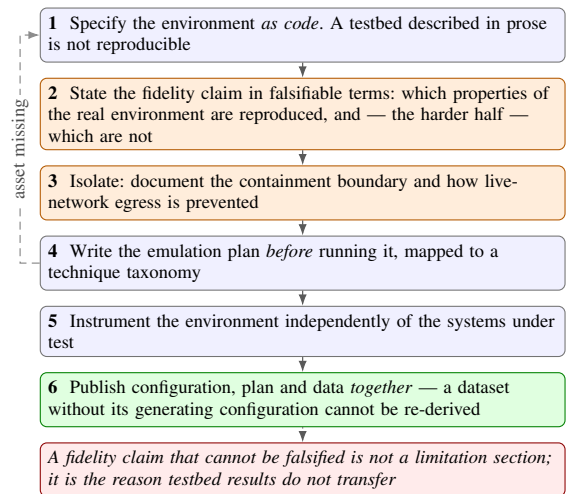


Fig. 12. Family J. Steps 2 and 3 are gates for opposite reasons: an unfalsifiable fidelity claim makes the result untransferable, and an undocumented containment boundary makes the experiment unsafe to repeat. Writing the emulation plan at step 4 routinely reveals assets the environment does not have, which is why the specification at step 1 has to be re-openable rather than fixed once.

G. Checklist

- Environment specified as code.
- Fidelity claim stated falsifiably, including what is not reproduced.
- Containment boundary documented; live-network egress prevented.
- Emulation plan written before execution and mapped to a technique taxonomy.
- Instrumentation independent of the systems under test.
- Configuration, plan and data published together.

XIV. FAMILY K: FIELD EXPERIMENTS, TRAINING AND AWARENESS EVALUATION

A. Purpose and when to use it

This family answers whether an intervention changes what people do. It is the only family that licenses a causal claim about behaviour, and it requires randomisation to do so.

B. Field experiments

The canonical enterprise instance is the phishing simulation, and the methodological question is what the simulation is for. A field experiment on learning through post-simulation feedback compared embedded and non-embedded feedback and reported effects on subsequent behaviour [127]. The design elements that make such a study interpretable: assignment at a unit that prevents contamination between conditions (commonly the team or department rather than the individual, since colleagues talk); a pre-registered primary outcome; an intention-to-treat analysis; and an ethics approval that covers deception of employees.

Report against CONSORT. It is the reporting standard for a parallel-group randomised trial, and the enterprise field experiment is one: its 25 items ask how the allocation sequence was generated, how it was concealed until assignment, who

was blinded, how many units were assigned and how many were analysed, and why anyone dropped out [128]. The flow diagram it requires, assessed, assigned, received, followed up, analysed, is the single most useful artifact a phishing-simulation study can publish, because it makes visible the employees who left the company mid-study, the department that was excluded after the fact, and the difference between the units randomised and the units analysed. Wohlin et al.'s treatment of experimentation in software engineering supplies the design vocabulary underneath it, experiment scoping, planning, operation, analysis and presentation, with the standard threat classification of conclusion, internal, construct and external validity, in a form closer to the conditions of a security experiment than the clinical literature is [129].

C. Training and range-based education

Adaptive training begins from trainee needs, assesses performance continuously and raises difficulty progressively; implemented on a cyber-range platform for smart-shipping personnel, it was evaluated through performance outcomes, knowledge acquisition, retention and incident-response capability [130]. Game-based approaches replace instruction with decision-making; the CyberCIEGE evaluation reported improved engagement and application of concepts in simulated environments [131]. Both are formative evaluations.

Two recent studies show what the summative version looks like, and both are worth copying structurally rather than topically. Glas et al. re-designed an existing cyber-range exercise for tier-one analysts in a commercial security-operations centre around instructional-design principles, structured feedback, scaffolding, competitive elements, and evaluated the re-design in a randomised controlled trial with 144 participants drawn from cybersecurity courses at two universities, assigned to the original or the revised learning-management system. They report better learning experience and shorter training time with equivalent knowledge outcomes [132]. The design point is the comparator: the control condition was the exercise the organisation was already running, so the study measures the increment attributable to the re-design rather than the effect of training versus nothing.

Lee et al. address the other standing weakness of this literature, that training is evaluated away from the job it is meant to change. Their intervention runs gamified phishing training inside employees' ordinary work context over several weeks rather than in a dedicated session, and a randomised field experiment found better phishing detection and avoidance in the treatment group than in the control; they also model a psychological mechanism, mindfulness of phishing, rather than reporting the effect alone [133]. Proposing a mechanism and testing a path model is what distinguishes a study that explains an effect from one that only records it, and it is the part most awareness evaluations omit.

D. Awareness programme evaluation

Measuring whether employees completed training measures compliance with a training policy, not awareness. A framework derived from a review of 32 papers adapts four indicators from

the European Literacy Policy Network, impact, sustainability, accessibility and monitoring, to make awareness evaluation systematic and repeatable [19]. Small and medium-sized enterprises are identified as an evidence-poor context with respect to awareness needs, resources, expertise and incentives [134].

E. Human-subjects methodology in security

Empirical methods in usable security have themselves been reviewed systematically, with attention to how risk is represented to participants, a design choice that determines whether participants behave as they would under real stakes [135]. The generalisation caution of Section VII applies with full force here [67].

F. What the evidence supports

Confidence: Moderate that ranges, adaptive progression and interactive exercises improve engagement and short-term performance indicators. **Confidence: Limited** for long-term effectiveness: sustained retention, organisational behaviour change and scalability are not consistently evaluated in this corpus.

G. Checklist

- Randomisation unit stated and contamination addressed.
- Allocation concealment described.
- Primary outcome pre-specified.
- Intention-to-treat analysis.
- CONSORT flow reconciling units randomised with units analysed.
- Ethics approval covering any deception.
- Debriefing procedure.
- Outcome measured as behaviour rather than completion.
- Comparator stated as the incumbent practice where one exists.
- Follow-up at a stated interval.
- Effect size with an interval, not only a *p*-value.

The protocol is illustrated in Figure 13.

XV. OPERATIONS, INCIDENT RESPONSE AND MATURITY

Operational research cuts across the families above and deserves separate treatment because its evaluation problem is distinctive: the object of study is a capability, not a component.

Threat-intelligence research identifies a persistently technology-centred discourse and argues that operationalisation requires attention to processes, practitioners, artifacts, organisational strategy and sharing practice [5]. The CTI-SOC2M2 maturity model links intelligence integration to security-operations service maturity and was evaluated through expert interviews and a prototype [36]. Practice-oriented incident-response guidance emphasises policy, roles, documented procedures, threat modeling, risk assessment, regular exercises, self-assessment, third-party assessment and independent audit [136], aligned to the current cybersecurity framework [137]. Incident-response team research stresses repeatable process, response speed, learning from incidents and information sharing [138].

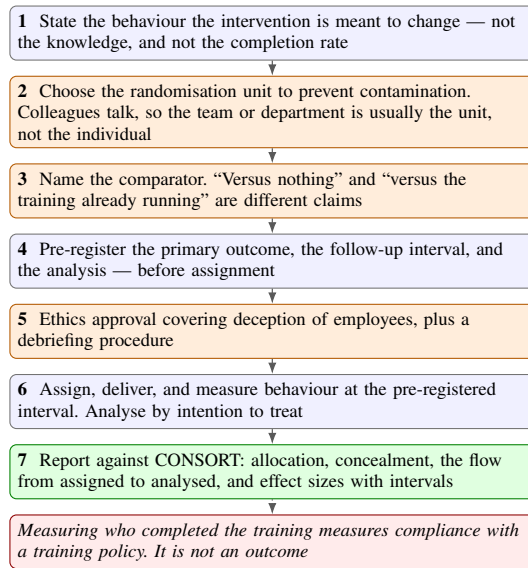


Fig. 13. Family K. This is the only family in the review that licenses a causal claim about behaviour, and every gate exists to protect that licence. Step 2 protects internal validity, step 3 decides what the effect is an effect of, and step 5 is a gate in the literal sense: a phishing simulation deceives employees, and without approval and debriefing the study should not run. Step 4 must precede assignment, which is why it cannot be added during analysis.

The methodological lesson is that maturity must be assessed as a capability system rather than reduced to a single score. **Confidence: Moderate** for the value of structured, repeatable, intelligence-informed process. **Confidence: Limited** for cross-organisational comparison, because the literature has not converged on validated measures of incident-response effectiveness and organisational resources and commitment vary widely.

For researchers, this implies a specific design: pair a maturity instrument with an independent outcome measure. A maturity level that correlates with nothing observable is a description of documentation, not of capability.

A. Process models as research objects: the forensic case

Incident response and digital forensics share a methodological problem the rest of this review does not have: the process itself is the artifact under scrutiny, and it may have to survive examination in court. That raises the standard of what counts as a validated process, and the digital-forensics literature is where the standard has been worked out.

The instructive line of work is the harmonisation effort. Valjarevic and Venter observed that the field had accumulated many partially overlapping investigation process models, no two of which decomposed the work the same way, and proposed a harmonised model built by reconciling the existing ones, an exercise in method consolidation rather than method invention [139]. The extended treatment develops the model comprehensively and, more importantly for a methodologist, states the criteria by which such a model should be judged: completeness against the phases the field recognises, and a correspondence between the model's steps and the evidential requirements they serve [140]. A researcher proposing any

process model, for response, for triage, for threat hunting, owes the same two things, and most proposals supply neither.

Hargreaves et al. take the layer below. Rather than modelling the investigation, they model the *tool*: an abstract model of what a digital-forensic analysis tool does, given as a foundation for systematic error-mitigation analysis, so that the places a tool can be wrong can be enumerated rather than discovered by accident [141]. This is a generalisable move and an under-used one. Where a field's results depend on tooling, as detection research depends on parsers, feature extractors and labelling scripts, an explicit model of the tool is what turns “the tool has bugs” from a caveat into an analysable error budget.

B. Prioritising organisational change under disagreement

Capability programmes fail on ordering as often as on content: an organisation cannot do 33 things at once, and which to do first is a judgement no single stakeholder holds. Pigola and Meirelles treat that ordering as the research question. Working with a panel of 29 professionals, they elicit the criteria that govern zero-trust adoption using a fuzzy Delphi procedure, which admits that expert judgements are imprecise rather than forcing them to a point, and then weight the criteria with CRITIC, which derives importance from the correlation structure among the criteria instead of from further expert opinion. They report four dimensions, culture, operations and processes, compliance, and investments, across 33 criteria, and they note that the resulting rank can reverse under changing conditions [142].

That last observation is the methodological content, and it generalises past zero trust. A multi-criteria weighting is a snapshot of a preference structure; reporting the ranking without testing its stability presents a contingent ordering as a finding. Any study using this family of methods should report the sensitivity of its ranking to the weights, in the same spirit as the sensitivity analysis Figure 8 requires of a simulation. The pairing of an opinion-based elicitation step with a correlation-based weighting step is also worth noting on its own: it is a deliberate attempt to keep the panel from setting both the criteria and their importance.

The protocol is illustrated in Figure 14.

XVI. CROSS-CUTTING CONCERNS

A. Validity, stated as four questions

Every study in every family should answer four questions explicitly.

- **Construct validity.** Does the measure correspond to the concept? A model's F_1 on a benchmark is a construct measure of “ability to separate labelled classes in that benchmark”, which is not the same construct as “detects intrusions in an enterprise”. Naming the gap is the whole of the obligation.
- **Internal validity.** Could the observed effect have another cause? Data leakage, ordering effects, an uncontrolled confound between conditions, an expert who both supplies parameters and validates outputs.

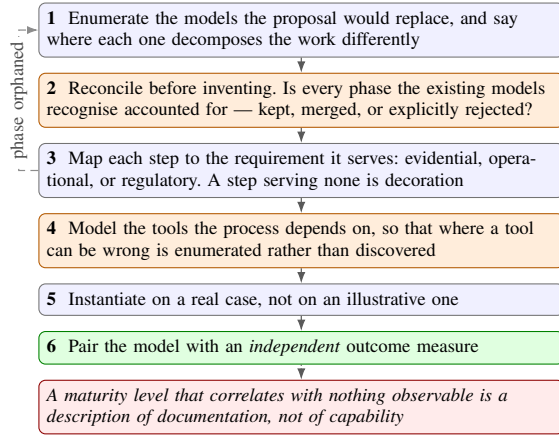


Fig. 14. Validating a proposed process or maturity model, in the sense Section XV argues for. The two gates are what separate a model from a diagram. Step 2 is the harmonisation discipline the digital-forensics literature arrived at after accumulating models faster than it could reconcile them; step 4 is the layer below, where the process is only as sound as the tools it delegates to. Step 6 is the one this review found most often missing across operational research generally.

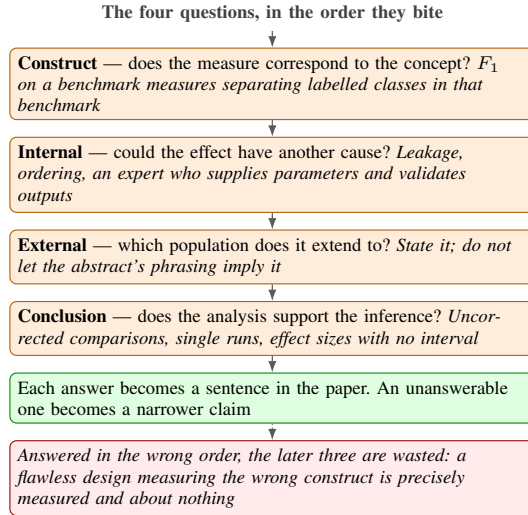


Fig. 15. The validity questions every family owes, drawn in order because the order is not arbitrary. Construct validity is first because it can invalidate the study outright; conclusion validity is last because it is the only one that can be repaired after the data are collected. The italic text in each box is the failure this review encountered most often for that question.

- **External validity.** To which population does the result extend? State the population; do not let the reader infer it from the abstract’s phrasing.
- **Conclusion validity.** Does the analysis support the inference? Multiple comparisons without correction, single-run differences, and effect sizes reported without intervals are the recurring problems.

These threats to validity are mapped in Figure 15.

B. Reporting standards, by family

Table III maps the families onto the reporting instruments that exist for them. Two features of the table are the reason to print it. First, most of the usable standards were written outside computer security, in medicine, epidemiology and the

TABLE III
REPORTING STANDARDS BY FAMILY. EMPTY ROWS RECORD STANDARDS WE COULD NOT LOCATE, NOT A SEARCHED-OUT ABSENCE.

Family	Instrument
A Secondary	PRISMA 2020 [30]; PRISMA-P for the protocol [32]; PRISMA-ScR for scoping reviews [33]
B Design science	— (use the evaluation ladder, Figure 4)
C Qualitative	COREQ for interviews and focus groups [61]; SRQR more generally [62]
D Survey	CHERRIES for web-administered instruments [66]
E Threat modeling	—
F Simulation	—
G Machine learning	TRIPOD, translated from prediction modelling [103]
H Language models	—
I Measurement	STROBE [119]
J Testbeds	—
K Field experiments	CONSORT [128]
Rating a body of evidence	GRADE [16]

social sciences, and transfer with a change of vocabulary rather than a change of substance; declining to use one because it says “participants” where a security paper says “hosts” is not a methodological objection. Second, five of the eleven families have no reporting standard that we could locate, and those five, threat modeling, simulation, language-model evaluation, testbeds, and design science, are, not coincidentally, the families in which this review found protocol details most often unreported. We did not run a systematic search for candidate standards in the empty rows, so each records an absence in our retrieval rather than a demonstrated absence in the literature. Where the row is empty, the family’s checklist in the corresponding section is the substitute, and it is a weaker one: a checklist an author may not have read cannot do what a standard a reviewer expects does.

C. Reproducibility and artifact sharing

Reproducibility in applied security has been measured, not merely lamented. A reproducibility study of security research assessed how far published work could actually be re-run [143], and an eleven-year review of artifacts at applied security conferences documents the trajectory of artifact availability and evaluation [144]. Data sharing and reuse practices in the community have been examined directly, including what researchers do with data they obtain and what prevents them from releasing it [145]. The practical minimum for a new study: release code with a pinned dependency specification; release the exact data split, or the script that regenerates it from a stated source; record environment and seeds; and separate the artifact that reproduces the paper’s figures from the general-purpose library.

The surrounding practice has a name and a literature. Mendez et al. set out open science for software engineering as a set of concrete, separable commitments, open access, open data, open source, and pre-registration, together with the

objections researchers actually raise against each and the conditions under which each is achievable [146]. Treating them as separable matters in security, because the commitments are not equally available: a study on production telemetry may be unable to open its data and perfectly able to open its code and pre-register its analysis. Declaring which commitments were met and why the others were not is more informative than an artifact badge.

Releasing an artifact also creates an obligation that artifact evaluation does not currently cover. Rani and Rossow examined 509 artifacts from top-tier security venues and report that many contain insecure code patterns; after static analysis and manual filtering of false positives, they judge that 41.60% of the prevalent findings pose potential security concerns under practical usage, and they propose both a taxonomy for context-aware assessment and a framework, SAFE, for triaging tool-reported findings [147]. The point for an author is narrow and actionable: artifact evaluation asks whether the artifact *works*, not whether it is safe for a stranger to run, and those are different questions. Anything shipped with a research paper should at minimum have its dependencies pinned, its network behaviour documented, and any credential, key or permissive default removed before release.

D. Disclosure as part of the method

Where a study finds a live weakness, disclosure is not an epilogue to the research; it is a step in it, with its own timeline and its own failure modes. Ayala et al. study the mechanism empirically, analysing 3,798 reviewed GitHub security advisories and 4,033 disclosed open-source bug-bounty reports to trace how a vulnerability propagates from reporter to maintainer to dependent project to the global vulnerability databases [148]. What they find in that pipeline is where the delay lives: missing or late CVE assignment means dependent projects are not notified when they need to be. A researcher who plans to disclose should design for that pipeline rather than assume it, identify who can actually issue an identifier for the affected component, start the clock at report rather than at publication, and state the disclosure timeline in the paper so that a reader can judge whether publication preceded the fix.

E. Ethics and legal constraints

Security research touches systems and people who did not consent to being studied. The Menlo Report’s application of ethical principles to information and communication technology research, respect for persons, beneficence, justice, respect for law and public interest, is the field’s reference framework [149]. In enterprise research specifically, three recurring issues need addressing in the paper itself: employee deception in phishing studies, which requires approval and debriefing; access to production telemetry, which requires a data-handling agreement and usually irreversible de-identification; and disclosure, where a study that finds a live weakness incurs an obligation that precedes publication.

The Menlo principles tell you which considerations are in play; they do not adjudicate between them when they conflict,

and in security they routinely do. Kohno et al. address exactly that gap, introducing ethical frameworks, consequentialist, deontological and others, to a security audience and working through hypothetical dilemmas designed so that different frameworks give different answers [150]. The reason to read it is not to adopt a framework but to be able to say which one a decision rests on. “We obtained approval” records that a committee agreed; it does not record the reasoning, and a paper whose ethical argument is a procedural fact has not made an argument. Where a study imposed a cost on someone, deceived employees, degraded a service, collected data about non-participants, name the cost, name the benefit set against it, and name the principle under which the trade was made.

F. From result to claim

The final cross-cutting discipline is the one most often skipped. Every claim in a paper should trace to a specific artifact, a table, a run, a transcript, a log, and the strength of the wording should match the strength of that trace. In practice this means maintaining a claim-to-evidence table alongside the draft, in which each claim names its supporting artifact and the verification status of that artifact, and reserving strong comparative language for claims whose supporting evidence has been checked. Where the artifact is missing or ambiguous, the correct action is to weaken the claim or to ask the party who holds the data, not to write around the gap. This is the discipline that would have caught the unreconciled screening figures described in Section II-G.

XVII. READING THE CONTRADICTIONS

The corpus contains one contradiction sharp enough to be instructive, and working through it teaches more about evaluation design than any checklist.

A. The contradiction

Four careful comparative studies rank intrusion-detection algorithms differently.

- A comparative study of machine-learning intrusion-detection methods found ensemble methods generally strong, while naive Bayes showed lower accuracy on learned data but trained faster and had advantages in recognising new attack types [98].
- A controlled comparison of four deep-learning architectures across KDD 99, NSL-KDD, CIC-IDS2017 and CIC-IDS2018 found deep feed-forward networks best on accuracy, F_1 , training time and inference time, with autoencoders and deep belief networks not exceeding supervised feed-forward networks [97].
- A recurrent-network intrusion-detection system was reported as superior to J48, artificial neural networks, random forest and support vector machines in both binary and multiclass classification [102].
- A later comparison found convolutional and recurrent models reaching 98% accuracy while random forest reached 99.9% [17].

These cannot all be descriptions of a stable ranking.

B. The resolution

The contradiction is not resolvable by choosing a winner, and attempting to do so is the error. The results differ because the studies differ in dataset composition, feature representation, preprocessing, network context, class balance, architecture and hyperparameter budget, and each of those is known to move the reported number by more than the margins that separate the studies. What the set of studies establishes jointly is therefore not a ranking but a constraint: *headline accuracy on a benchmark is not a stable estimate of enterprise performance*, and a paper that reports one as though it were has overstated its result regardless of how carefully the experiment was run. The limit of the argument should be stated with it: attributing the inversion to any single design factor would require re-running representative models under one harmonised protocol, which this review does not do (Section XIX). The claim is that the joint design variation is sufficient to account for margins of the size observed, not that any one factor has been isolated.

The hybrid-ensemble case illustrates the limit precisely. Combining XGBoost, random forest, a graph neural network, long short-term memory and autoencoders under SMOTE and weighted soft voting, with five-fold cross-validation and an independent benchmark, produced accuracy, precision, recall and F_1 approaching 100% [18]. The internal comparison is stronger than most. And the study itself reports computational overhead, inference latency, overfitting risk and the absence of explicit evaluation against unseen attack types. Stronger validation improved credibility without removing deployment uncertainty, which is exactly the right outcome to expect and exactly the outcome that a reader in a hurry will misread.

Publication bias is a plausible additional contributor, positive technical results are more likely to be written up than failed implementations, though the available data do not permit its magnitude to be estimated here.

C. What a researcher should do about it

- 1) Evaluate across multiple datasets, and report per-dataset results rather than an average that conceals the variation.
- 2) Use a temporally consistent split whenever the claim concerns future performance [85].
- 3) Report the false-alarm rate at a realistic base rate, not only recall (Equation (7)).
- 4) Include a simple baseline. Where random forest reaches 99.9% on a benchmark, that benchmark is telling you something about itself.
- 5) Report computational cost alongside accuracy, since the deployment decision trades them off.
- 6) Test against attack types absent from training, and report the degradation.

XVIII. THREE WORKED PROTOCOLS

The families combine. Three templates cover a large share of realistic enterprise studies. Figure 16 places them side by side, in the shared notation used for the individual families, so that the composition is legible as a composition: each recipe is a path through three families rather than a fourth methodology.

A. Recipe 1: Evaluating a detection approach for a real deployment

Families G, I, J. Establish the telemetry available in the target environment and measure its coverage of the behaviours of interest (§XII). Build a testbed that reproduces the relevant portion of the environment and specify it as code (§XIII). Write an emulation plan and generate labelled data with known ground truth. Train on a temporally earlier window and test on a later one (§X-D). Report the confusion matrix, the false-alarm rate at the environment's actual base rate, per-dataset results, and inference cost. Then run the model against a held-out period containing behaviours absent from training, and report the degradation as a finding rather than a limitation.

B. Recipe 2: Studying a security-operations practice

Families C, A, B. Begin with a rapid review to establish what is already claimed (§IV). Conduct semi-structured interviews with practitioners across at least three organisations, sampling for variation in size and sector rather than for convenience (§VI). Analyse reflexively, with an audit trail. If the analysis suggests an artifact, a process model, a maturity instrument, a decision aid, develop it as design science with objectives fixed in advance (§V), and evaluate it with practitioners who were not among the interviewees. Report the formative-summative distinction honestly.

C. Recipe 3: Quantifying risk in an enterprise architecture

Families E, F, I. Decompose the architecture and enumerate threats with STRIDE to establish coverage (§VIII). Convert to an attack graph so that multi-step paths are representable, and parameterise it, labelling each parameter as measured, estimated or assumed. Where deployed security products can supply inputs automatically, prefer that to elicitation [73]. Compute the risk quantities and then run sensitivity analysis across the assumed parameters; report any conclusion that inverts within their plausible range. Validate against an independent source, incident history, or the judgement of experts who did not supply the parameters. Report the model, the parameters and the sensitivity results together; a probability without its parameter provenance is not interpretable.

XIX. GAPS AND A RESEARCH AGENDA

A. Gaps in the field

- 1) **Evaluation in continuously operating enterprises.** The largest gap. Detection studies rest on KDD 99, NSL-KDD, CIC-IDS2017, CIC-IDS2018, synthetic attacks and simulated traffic; risk and cyber-physical studies rest on modelled systems. Work that combines benchmark reproducibility with longitudinal enterprise telemetry, multiple independent organisations, changing attack distributions and explicit unseen-attack testing would resolve more open questions than any further architecture comparison.
- 2) **Harmonised comparison protocols.** The contradiction in Section XVII cannot be resolved without shared preprocessing, feature selection, imbalance treatment,

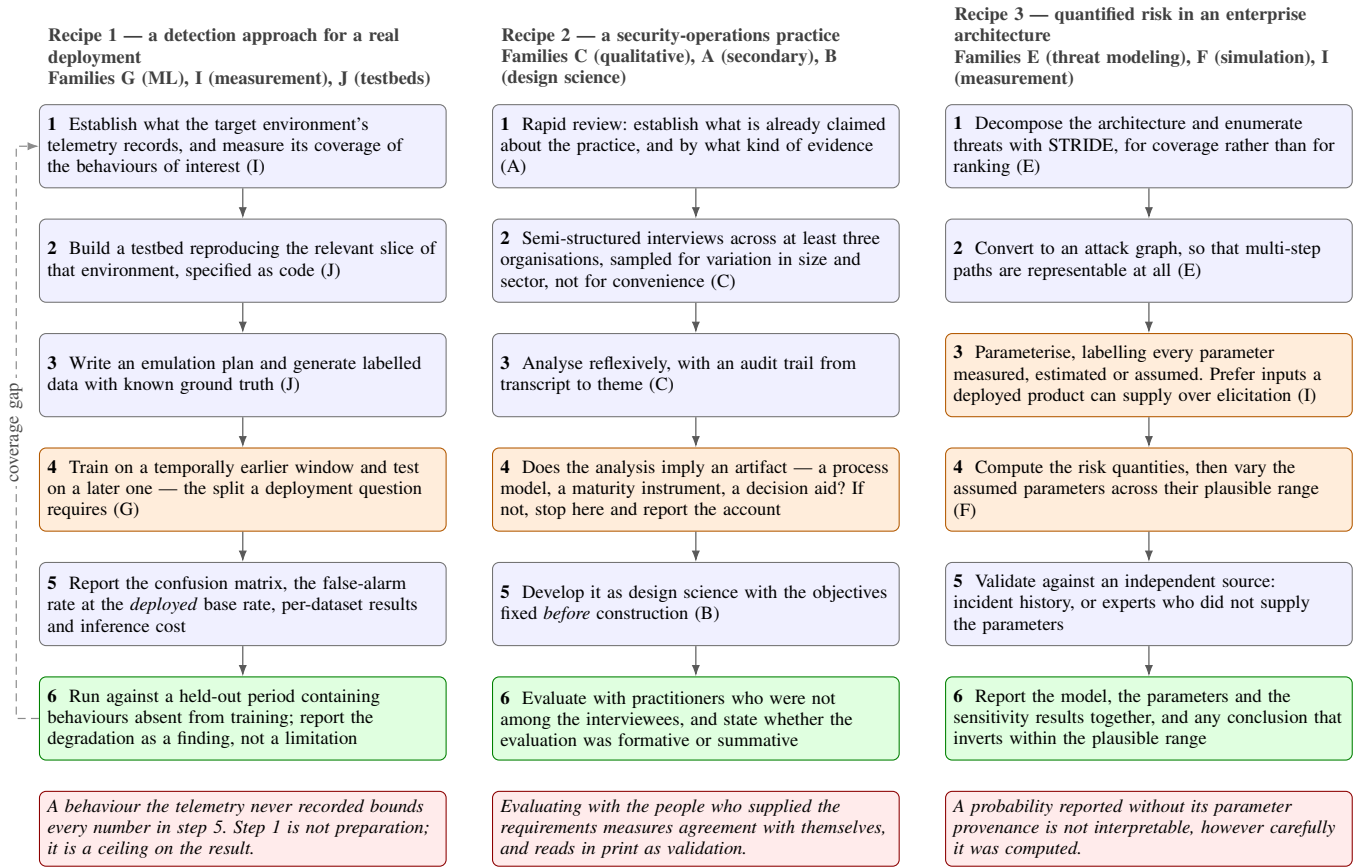


Fig. 16. The three worked protocols, side by side. Read down a column for one study; read across for what the three have in common. Each begins by fixing what can be observed or claimed at all (steps 1–2), forces a decision that determines what the result will license (the orange gate), and ends with an output whose required contents are stated rather than left to the author (green). The red band is the recipe's characteristic failure: in each case it is a defect introduced early that no later rigour repairs, which is why the ordering is part of the protocol.

hyperparameter reporting, cost measurement and train-test protocol.

- 3) **Validated outcome measures for operations.** Incident-response and awareness research lacks measures that link exercises, training and intelligence integration to response performance. Until those exist, maturity comparisons across organisations are not interpretable.
- 4) **Interaction-level threat modeling.** STRIDE's documented blind spot, threats arising from component interaction rather than from components, remains open [69].
- 5) **Uncertainty reporting in probabilistic risk models.** Models should report their data requirements and their sensitivity to incomplete telemetry, which is the normal operating condition.
- 6) **Under-represented contexts.** Small and medium-sized enterprises, non-technical employees, small security-operations teams, and enterprises outside finance, health-care, critical infrastructure and transport [46], [134]. A ransomware-mitigation model developed and validated for micro and small enterprises is one of the few direct engagements with this population [151].
- 7) **Evaluation methodology for agentic systems,** which is younger than the systems it is asked to assess (§XI).

B. Gaps in this review

We under-covered three facets and name them so that a reader does not mistake absence for evidence of absence: operational security metrics such as mean time to detect and mean time to respond; insider-threat study design; and the design of studies that recruit adversaries or observe them at scale. Deception measurement and forensic process validation are treated here only as far as their study designs go (§XII, §XV); neither receives the family-level treatment given to the eleven, and both would support one. The same is true of the three facets above: each merits the treatment given to the eleven families here.

XX. CONCLUSION

Enterprise cybersecurity research is best conducted through a combination of methodologies rather than a single all-purpose design. Secondary research organises fragmented knowledge; design science produces and tests artifacts; controlled experiments compare detection methods; threat modeling and probabilistic analysis structure risk; simulation permits safe evaluation of complex and cyber-physical systems; qualitative, mixed and longitudinal approaches reveal the organisational, cognitive and behavioural conditions that technical metrics do not reach.

The technical evidence is promising and uneven. Reported detection performance is high but the ranking among approaches is inconsistent across studies; we argue the inconsistency is better explained by evaluation design than by the algorithms, since the studies differ jointly — in dataset, preprocessing, class balance and tuning budget — by more than the margins that separate them, though no single factor has been isolated (Section XVII). Risk-modeling approaches produce usable probabilities in virtual enterprise networks and await broader replication [73]. Organisational studies supply the complementary evidence that communication, decision load, human factors, intelligence integration and temporal variation in behaviour shape security outcomes [20], [43], [45].

The unresolved question is whether these methods retain their reported effectiveness under changing enterprise conditions, unseen attacks, incomplete telemetry, shifting employee behaviour, legacy systems and resource constraints. Answering it requires triangulating models, operational data, practitioner evidence and longitudinal evaluation. Two habits do most of the work in getting there, and neither requires new technique: state the population a result generalises to, and state the observation that would have shown the approach did not work. A literature that did both consistently would resolve most of the contradictions catalogued here without running a single additional experiment.

APPENDIX A

CONSOLIDATED REPORTING CHECKLISTS

Table IV consolidates the per-family checklists into the items most frequently absent from published work in this corpus. It is intended for use both when writing and when reviewing.

REFERENCES

- [1] Y. Jiang, M. A. Jeusfeld, J. Ding, and E. Sandahl, "Model-Based Cybersecurity Analysis: Extending Enterprise Modeling to Critical Infrastructure Cybersecurity," *Business & Information Systems Engineering*, vol. 65, no. 6, p. 643–676, May 2023. [Online]. Available: <http://dx.doi.org/10.1007/s12599-023-00811-0>
- [2] X. Koutsoukos, G. Karsai, A. Laszka, H. Neema, B. Potteiger, P. Volgyesi, Y. Vorobeychik, and J. Sztipanovits, "SURE: A Modeling and Simulation Integration Platform for Evaluation of Secure and Resilient Cyber-Physical Systems," *Proceedings of the IEEE*, vol. 106, no. 1, p. 93–112, January 2018. [Online]. Available: <http://dx.doi.org/10.1109/jproc.2017.2731741>
- [3] R. Leszczyna, "Review of cybersecurity assessment methods: Applicability perspective," *Computers & Security*, vol. 108, p. 102376, 2021.
- [4] A. Y. Wong, E. G. Chekole, M. Ochoa, and J. Zhou, "On the Security of Containers: Threat Modeling, Attack Analysis, and Mitigation Strategies," *Computers & Security*, vol. 128, p. 103140, May 2023. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2023.103140>
- [5] S. Ainslie, D. Thompson, S. Maynard, and A. Ahmad, "Cyber-threat intelligence for security decision-making: A review and research agenda for practice," *Computers & Security*, vol. 132, p. 103352, 2023.
- [6] A. G. Kotulic and J. G. Clark, "Why there aren't more information security research studies," *Information & Management*, vol. 41, no. 5, p. 597–607, May 2004. [Online]. Available: <http://dx.doi.org/10.1016/j.im.2003.08.001>
- [7] C. Herley and P. Van Oorschot, "SoK: Science, Security and the Elusive Goal of Security as a Scientific Pursuit," in *2017 IEEE Symposium on Security and Privacy (SP)*. IEEE, May 2017, p. 99–120. [Online]. Available: <http://dx.doi.org/10.1109/sp.2017.38>
- [8] H. Snyder, "Literature review as a research methodology: An overview and guidelines," *Journal of Business Research*, vol. 104, p. 333–339, November 2019. [Online]. Available: <http://dx.doi.org/10.1016/j.jbusres.2019.07.039>
- [9] B. N. Green, C. D. Johnson, and A. Adams, "Writing narrative literature reviews for peer-reviewed journals: secrets of the trade," *Journal of Chiropractic Medicine*, vol. 5, no. 3, p. 101–117, 2006.
- [10] R. Ferrari, "Writing narrative style literature reviews," *Medical Writing*, vol. 24, no. 4, p. 230–235, December 2015. [Online]. Available: <http://dx.doi.org/10.1179/2047480615z.000000000329>
- [11] E. S. Barry, J. Merkebu, and L. Varpio, "State-of-the-art literature review methodology: A six-step approach for knowledge synthesis," *Perspectives on Medical Education*, vol. 11, no. 5, p. 1–8, 2022.
- [12] D. Turnbull, R. Chugh, and J. Luck, "Systematic-narrative hybrid literature review: A strategy for integrating a concise methodology into a manuscript," *Social Sciences & Humanities Open*, vol. 7, no. 1, p. 100381, 2023. [Online]. Available: <http://dx.doi.org/10.1016/j.ssaho.2022.100381>
- [13] G. Wong, T. Greenhalgh, G. Westhorp, J. Buckingham, and R. Pawson, "RAMESES publication standards: meta-narrative reviews," *BMC Medicine*, vol. 11, no. 1, January 2013. [Online]. Available: <http://dx.doi.org/10.1186/1741-7015-11-20>
- [14] G. Wong, T. Greenhalgh, G. Westhorp, and R. Pawson, "Development of methodological guidance, publication standards and training materials for realist and meta-narrative reviews: the RAMESES (Realist And Meta-narrative Evidence Syntheses – Evolving Standards) project," *Health Services and Delivery Research*, vol. 2, no. 30, p. 1–252, 2014.
- [15] E. van der Kouwe, G. Heiser, D. Andriess, H. Bos, and C. Giuffrida, "SoK: Benchmarking Flaws in Systems Security," in *2019 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2019, p. 310–325.
- [16] G. H. Guyatt, A. D. Oxman, G. E. Vist, R. Kunz, Y. Falck-Ytter, P. Alonso-Coello, and H. J. Schünemann, "GRADE: an emerging consensus on rating quality of evidence and strength of recommendations," *BMJ*, vol. 336, no. 7650, p. 924–926, April 2008. [Online]. Available: <http://dx.doi.org/10.1136/bmj.39489.470347.ad>
- [17] M. L. Ali, K. Thakur, S. Schmeelk, J. DeBello, and D. Dragos, "Deep Learning vs. Machine Learning for Intrusion Detection in Computer Networks: A Comparative Study," *Applied Sciences*, vol. 15, no. 4, p. 1903, February 2025. [Online]. Available: <http://dx.doi.org/10.3390/app15041903>
- [18] R. Almuhan and S. Dardouri, "A deep learning/machine learning approach for anomaly based network intrusion detection," *Frontiers in Artificial Intelligence*, vol. 8, 2025.
- [19] S. Chaudhary, V. Gkioulos, and S. Katsikas, "Developing metrics to assess the effectiveness of cybersecurity awareness program," *Journal of Cybersecurity*, vol. 8, no. 1, January 2022. [Online]. Available: <http://dx.doi.org/10.1093/cybsec/tyac006>
- [20] W. A. Cram, J. D'Arcy, and A. Benlian, "Time Will Tell: The Case for an Idiographic Approach to Behavioral Cybersecurity Research," *MIS Quarterly*, vol. 48, no. 1, p. 95–136, March 2024. [Online]. Available: <http://dx.doi.org/10.25300/misq/2023/17707>
- [21] R. Chinnasamy, M. Subramanian, S. V. Easwaramoorthy, and J. Cho, "Deep learning-driven methods for network-based intrusion detection systems: A systematic review," *ICT Express*, vol. 11, no. 1, p. 181–215, February 2025. [Online]. Available: <http://dx.doi.org/10.1016/j.icte.2025.01.005>
- [22] M. M. Yamin, B. Katt, and V. Gkioulos, "Cyber ranges and security testbeds: Scenarios, functions, tools and architecture," *Computers & Security*, vol. 88, p. 101636, January 2020. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2019.101636>
- [23] M. Alhamed and M. M. H. Rahman, "A Systematic Literature Review on Penetration Testing in Networks: Future Research Directions," *Applied Sciences*, vol. 13, no. 12, p. 6986, 2023.
- [24] T. Y. Khaw, A. Amran, and A. P. Teoh, "Building a thematic framework of cybersecurity: a systematic literature review approach," *Journal of Systems and Information Technology*, vol. 26, no. 2, p. 234–256, April 2024. [Online]. Available: <http://dx.doi.org/10.1108/jsit-07-2023-0132>
- [25] K. Petersen, S. Vakkalanka, and L. Kuzniarz, "Guidelines for conducting systematic mapping studies in software engineering: An update," *Information and Software Technology*, vol. 64, p. 1–18, August 2015. [Online]. Available: <http://dx.doi.org/10.1016/j.infsof.2015.03.007>
- [26] O. Lamberts, K. Wolsing, E. Wagner, J. Pennekamp, J. Bauer, K. Wehrle, and M. Henze, "SoK: Evaluations in Industrial Intrusion Detection Research," 2023, arXiv:2311.02929 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2311.02929>
- [27] S. Srivastava, K. Janardhan, and S. Jauhari, "A Systematic Review of Algorithmic Red Teaming Methodologies for Assurance and Security of AI Applications," 2026, arXiv:2602.21267 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2602.21267>

TABLE IV
CONSOLIDATED REPORTING ITEMS, BY FAMILY. ITEMS ARE THOSE MOST OFTEN ABSENT IN THE REVIEWED CORPUS.

Family	Report always	The item most often missing
Secondary research	Protocol, queries with dates, databases, snowballing, dual screening, PRISMA flow	Full-text exclusion reasons; a flow that reconciles
Design science	Measurable objectives fixed before build; artifact specification; evaluation type	Whether evaluation was formative or summative; the incumbent baseline
Qualitative	Sampling rationale, interview guide, coding procedure, reflexivity	Consistency between the design's rigour criterion and the statistic reported
Survey	Population versus frame, validated scales, power analysis, measurement model	The population the estimate generalises to
Threat modeling	Decomposition, method scope limit, parameter sources	Sensitivity analysis; separation of parameter suppliers from validators
Simulation	Model specification, parameter classification, replications	Verification distinct from validation; sensitivity on assumed parameters
Machine learning	Data provenance, split type, preprocessing placement, confusion matrix, cost	False-alarm rate at a realistic base rate; temporal consistency; seed variance
Language-model and agentic	Model version and date, attempts per task, judge calibration, environment	Contamination control; cost per task
Measurement	Ground-truth source, exact configuration, coverage before efficacy	Separation of logged, detected and alerted
Infrastructure	Environment as code, fidelity claim, containment, emulation plan	Which properties of reality the testbed does <i>not</i> reproduce
Field experiment	Randomisation unit, pre-specified outcome, intention-to-treat, ethics	Contamination between conditions; follow-up interval

- [28] C. Wohlin, "Guidelines for snowballing in systematic literature studies and a replication in software engineering," in *Proceedings of the 18th International Conference on Evaluation and Assessment in Software Engineering*, ser. EASE '14. ACM, May 2014, p. 1–10. [Online]. Available: <http://dx.doi.org/10.1145/2601248.2601268>
- [29] D. S. Cruzes and T. Dyba, "Recommended Steps for Thematic Synthesis in Software Engineering," in *2011 International Symposium on Empirical Software Engineering and Measurement*. IEEE, 2011, p. 275–284.
- [30] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan, R. Chou, J. Glanville, J. M. Grimshaw, A. Hróbjartsson, M. M. Lalu, T. Li, E. W. Loder, E. Mayo-Wilson, S. McDonald, L. A. McGuinness, L. A. Stewart, J. Thomas, A. C. Tricco, V. A. Welch, P. Whiting, and D. Moher, "The PRISMA 2020 statement: an updated guideline for reporting systematic reviews," *BMJ*, p. n71, March 2021. [Online]. Available: <http://dx.doi.org/10.1136/bmj.n71>
- [31] B. Kitchenham, O. Pearl Brereton, D. Budgen, M. Turner, J. Bailey, and S. Linkman, "Systematic literature reviews in software engineering – A systematic literature review," *Information and Software Technology*, vol. 51, no. 1, p. 7–15, January 2009. [Online]. Available: <http://dx.doi.org/10.1016/j.infsof.2008.09.009>
- [32] D. Moher, L. Shamseer, M. Clarke, D. Ghersi, A. Liberati, M. Petticrew, P. Shekelle, L. A. Stewart, and PRISMA-P Group, "Preferred reporting items for systematic review and meta-analysis protocols (PRISMA-P) 2015 statement," *Systematic Reviews*, vol. 4, no. 1, January 2015. [Online]. Available: <http://dx.doi.org/10.1186/2046-4053-4-1>
- [33] A. C. Tricco, E. Lillie, W. Zarin, K. K. O'Brien, H. Colquhoun, D. Levac, D. Moher, M. D. Peters, T. Horsley, L. Weeks, S. Hempel, E. A. Akl, C. Chang, J. McGowan, L. Stewart, L. Hartling, A. Aldcroft, M. G. Wilson, C. Garritty, S. Lewin, C. M. Godfrey, M. T. Macdonald, E. V. Langlois, K. Soares-Weiser, J. Moriarty, T. Clifford, Ö. Tunçalp, and S. E. Straus, "PRISMA Extension for Scoping Reviews (PRISMA-ScR): Checklist and Explanation," *Annals of Internal Medicine*, vol. 169, no. 7, p. 467–473, October 2018. [Online]. Available: <http://dx.doi.org/10.7326/m18-0850>
- [34] Z. Ahmad, A. Shahid Khan, C. Wai Shiang, J. Abdullah, and F. Ahmad, "Network intrusion detection system: A systematic study of machine learning and deep learning approaches," *Transactions on Emerging Telecommunications Technologies*, vol. 32, no. 1, October 2020. [Online]. Available: <http://dx.doi.org/10.1002/ett.4150>
- [35] G. Kocher and G. Kumar, "Machine learning and deep learning methods for intrusion detection systems: recent developments and challenges," *Soft Computing*, vol. 25, no. 15, p. 9731–9763, 2021.
- [36] D. Schlette, M. Vielberth, and G. Pernul, "CTI-SOC2M2 – The quest for mature, intelligence-driven security operations and incident response capabilities," *Computers & Security*, vol. 111, p. 102482, December 2021. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2021.102482>
- [37] P. Johnson, R. Lagerström, and M. Ekstedt, "A Meta Language for Threat Modeling and Attack Simulations," in *Proceedings of the 13th International Conference on Availability, Reliability and Security*, ser. ARES 2018. ACM, August 2018, p. 1–8. [Online]. Available: <http://dx.doi.org/10.1145/3230833.3232799>
- [38] D. G. Rosado, A. Santos-Olmo, L. E. Sánchez, M. A. Serrano, C. Blanco, H. Mouratidis, and E. Fernández-Medina, "Managing cybersecurity risks of cyber-physical systems: The MARISMA-CPS pattern," *Computers in Industry*, vol. 142, p. 103715, November 2022. [Online]. Available: <http://dx.doi.org/10.1016/j.compind.2022.103715>
- [39] M. N. Katsantonis, A. Manikas, I. Mavridis, and D. Gritzalis, "Cyber range design framework for cyber security education and training," *International Journal of Information Security*, vol. 22, no. 4, p. 1005–1027, March 2023. [Online]. Available: <http://dx.doi.org/10.1007/s10207-023-00680-4>
- [40] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A Design Science Research Methodology for Information Systems Research," *Journal of Management Information Systems*, vol. 24, no. 3, p. 45–77, December 2007. [Online]. Available: <http://dx.doi.org/10.2753/mis0742-1222240302>
- [41] A. R. Hevner, S. T. March, J. Park, and S. Ram, "Design Science in Information Systems Research," *MIS Quarterly*, vol. 28, no. 1, pp. 75–106, March 2004. [Online]. Available: <http://dx.doi.org/10.2307/25148625>
- [42] A. Shaked, "A model-based methodology to support systems security design and assessment," *Journal of Industrial Information Integration*, vol. 33, p. 100465, 2023.
- [43] R. van der Kleij, J. M. Schraagen, B. Cadet, and H. Young, "Developing decision support for cybersecurity threat and incident managers," *Computers & Security*, vol. 113, p. 102535, February 2022. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2021.102535>
- [44] G. Dhillon, K. Smith, and I. Dissanayaka, "Information systems security research agenda: Exploring the gap between research and practice," *The Journal of Strategic Information Systems*, vol. 30, no. 4, p. 101693, December 2021. [Online]. Available: <http://dx.doi.org/10.1016/j.jsis.2021.101693>
- [45] A. Ahmad, S. B. Maynard, and G. Shanks, "A case analysis of information systems and security incident responses," *International Journal of Information Management*, vol. 35, no. 6, p. 717–723, December 2015. [Online]. Available: <http://dx.doi.org/10.1016/j.ijinfomgt.2015.08.001>
- [46] R. Van der Kleij, G. Kleinhuis, and H. Young, "Computer Security Incident Response Team Effectiveness: A Needs Assessment,"

- Frontiers in Psychology*, vol. 8, December 2017. [Online]. Available: <http://dx.doi.org/10.3389/fpsyg.2017.02179>
- [47] F. B. Kokulu, A. Soneji, T. Bao, Y. Shoshitaishvili, Z. Zhao, A. Doupe, and G.-J. Ahn, "Matched and Mismatched SOCs: A Qualitative Study on Security Operations Center Issues," in *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS '19. ACM, November 2019, p. 1955–1970. [Online]. Available: <http://dx.doi.org/10.1145/3319535.3354239>
 - [48] E. Agyepong, Y. Cherdantseva, P. Reinecke, and P. Burnap, "Challenges and performance metrics for security operations center analysts: a systematic review," *Journal of Cyber Security Technology*, vol. 4, no. 3, p. 125–152, December 2019. [Online]. Available: <http://dx.doi.org/10.1080/23742917.2019.1698178>
 - [49] V. Braun and V. Clarke, "Using thematic analysis in psychology," *Qualitative Research in Psychology*, vol. 3, no. 2, p. 77–101, January 2006. [Online]. Available: <http://dx.doi.org/10.1191/1478088706qp0630a>
 - [50] —, "Is thematic analysis used well in health psychology? A critical review of published research, with recommendations for quality practice and reporting," *Health Psychology Review*, vol. 17, no. 4, p. 695–718, January 2023. [Online]. Available: <http://dx.doi.org/10.1080/17437199.2022.2161594>
 - [51] B. Saunders, J. Sim, T. Kingstone, S. Baker, J. Waterfield, B. Bartlam, H. Burroughs, and C. Jinks, "Saturation in qualitative research: exploring its conceptualization and operationalization," *Quality & Quantity*, vol. 52, no. 4, p. 1893–1907, 2017.
 - [52] W. Knowles, A. Baron, and T. McGarr, "The simulated security assessment ecosystem: Does penetration testing need standardisation?" *Computers & Security*, vol. 62, p. 296–316, 2016.
 - [53] A. Naiakshina, A. Danilova, C. Tiefenau, M. Herzog, S. Dechand, and M. Smith, "Why Do Developers Get Password Storage Wrong? A Qualitative Usability Study," in *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS '17. ACM, October 2017, p. 311–328. [Online]. Available: <http://dx.doi.org/10.1145/3133956.3134082>
 - [54] P. Runeson and M. Höst, "Guidelines for conducting and reporting case study research in software engineering," *Empirical Software Engineering*, vol. 14, no. 2, p. 131–164, December 2008. [Online]. Available: <http://dx.doi.org/10.1007/s10664-008-9102-8>
 - [55] C. Okoli and S. D. Pawlowski, "The Delphi method as a research tool: an example, design considerations and applications," *Information & Management*, vol. 42, no. 1, p. 15–29, December 2004. [Online]. Available: <http://dx.doi.org/10.1016/j.im.2003.11.002>
 - [56] W. Yeoh, M. Liu, M. Shore, and F. Jiang, "Zero trust cybersecurity: Critical success factors and A maturity assessment framework," *Computers & Security*, vol. 133, p. 103412, October 2023. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2023.103412>
 - [57] A. Pollini, T. C. Callari, A. Tedeschi, D. Ruscio, L. Save, F. Chiarugi, and D. Guerri, "Leveraging human factors in cybersecurity: an integrated methodological approach," *Cognition, Technology & Work*, vol. 24, no. 2, p. 371–390, 2021.
 - [58] J. R. Landis and G. G. Koch, "The Measurement of Observer Agreement for Categorical Data," *Biometrics*, vol. 33, no. 1, p. 159, March 1977. [Online]. Available: <http://dx.doi.org/10.2307/2529310>
 - [59] M. L. McHugh, "Interrater reliability: the kappa statistic," *Biochemia Medica*, p. 276–282, 2012. [Online]. Available: <http://dx.doi.org/10.11613/bm.2012.031>
 - [60] A. F. Hayes and K. Krippendorff, "Answering the Call for a Standard Reliability Measure for Coding Data," *Communication Methods and Measures*, vol. 1, no. 1, p. 77–89, April 2007. [Online]. Available: <http://dx.doi.org/10.1080/19312450709336664>
 - [61] A. Tong, P. Sainsbury, and J. Craig, "Consolidated criteria for reporting qualitative research (COREQ): a 32-item checklist for interviews and focus groups," *International Journal for Quality in Health Care*, vol. 19, no. 6, p. 349–357, 2007.
 - [62] B. C. O'Brien, I. B. Harris, T. J. Beckman, D. A. Reed, and D. A. Cook, "Standards for Reporting Qualitative Research: A Synthesis of Recommendations," *Academic Medicine*, vol. 89, no. 9, p. 1245–1251, 2014.
 - [63] S. Hina, D. D. D. Panneer Selvam, and P. B. Lowry, "Institutional governance and protection motivation: Theoretical insights into shaping employees' security compliance behavior in higher education institutions in the developing world," *Computers & Security*, vol. 87, p. 101594, November 2019. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2019.101594>
 - [64] J. Cohen, "A power primer," *Psychological Bulletin*, vol. 112, no. 1, p. 155–159, 1992. [Online]. Available: <http://dx.doi.org/10.1037/0033-2909.112.1.155>
 - [65] J. F. Hair, J. J. Risher, M. Sarstedt, and C. M. Ringle, "When to use and how to report the results of PLS-SEM," *European Business Review*, vol. 31, no. 1, p. 2–24, January 2019. [Online]. Available: <http://dx.doi.org/10.1108/eb-11-2018-0203>
 - [66] G. Eysenbach, "Improving the Quality of Web Surveys: The Checklist for Reporting Results of Internet E-Surveys (CHERRIES)," *Journal of Medical Internet Research*, vol. 6, no. 3, p. e34, 2004.
 - [67] E. M. Redmiles, S. Kross, and M. L. Mazurek, "How Well Do My Results Generalize? Comparing Security and Privacy Survey Results from MTurk, Web, and Telephone Samples," in *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, May 2019, p. 1326–1343. [Online]. Available: <http://dx.doi.org/10.1109/sp.2019.00014>
 - [68] C. C. Campbell, "Solutions for counteracting human deception in social engineering attacks," *Information Technology & People*, vol. 32, no. 5, p. 1130–1152, October 2019. [Online]. Available: <http://dx.doi.org/10.1108/itp-12-2017-0422>
 - [69] R. Khan, K. McLaughlin, D. Lavery, and S. Sezer, "STRIDE-based threat modeling for cyber-physical systems," in *2017 IEEE PES Innovative Smart Grid Technologies Conference Europe (ISGT-Europe)*. IEEE, 2017, p. 1–6.
 - [70] T. UcedaVélez and M. M. Morana, *Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis*. John Wiley & Sons, 2015, ISBN 978-0-470-50096-5.
 - [71] B. Potteiger, G. Martins, and X. Koutsoukos, "Software and attack centric integrated threat modeling for quantitative risk assessment," in *Proceedings of the Symposium and Bootcamp on the Science of Security*, ser. HotSoS '16. ACM, April 2016, p. 99–108. [Online]. Available: <http://dx.doi.org/10.1145/2898375.2898390>
 - [72] T. Sommestad, M. Ekstedt, and H. Holm, "The Cyber Security Modeling Language: A Tool for Assessing the Vulnerability of Enterprise System Architectures," *IEEE Systems Journal*, vol. 7, no. 3, p. 363–373, 2013.
 - [73] R. Sato, H. Kawaguchi, and Y. Nakatani, "Malcode: Practical and Stochastic Security Risk Assessment for Enterprise Networks," *IEEE Transactions on Dependable and Secure Computing*, vol. 22, no. 2, p. 1383–1399, March 2025. [Online]. Available: <http://dx.doi.org/10.1109/tdsc.2024.3434748>
 - [74] D. Palko, T. Babenko, A. Bigdan, N. Kiktev, T. Hutsol, M. Kuboń, H. Hnatienko, S. Tabor, O. Gorbovy, and A. Borusiewicz, "Cyber Security Risk Modeling in Distributed Information Systems," *Applied Sciences*, vol. 13, no. 4, p. 2393, February 2023. [Online]. Available: <http://dx.doi.org/10.3390/app13042393>
 - [75] S.-F. Wen, A. Shukla, and B. Katt, "Developing Security Assurance Metrics to Support Quantitative Security Assurance Evaluation," *Journal of Cybersecurity and Privacy*, vol. 2, no. 3, p. 587–605, August 2022. [Online]. Available: <http://dx.doi.org/10.3390/jcp2030030>
 - [76] K. Dong, J. Zhen, Z. Xie, and L. Chen, "Building cybersecurity resilience: integrating defense and recovery investment strategies in an expected resilience framework," *Journal of Enterprise Information Management*, vol. 38, no. 2, p. 502–531, October 2024. [Online]. Available: <http://dx.doi.org/10.1108/jeim-04-2023-0189>
 - [77] C. M. Graham, "Enhancing cybersecurity: a semantic network analysis of MITRE ATT&CK® techniques," *Information & Computer Security*, vol. 33, no. 5, p. 826–844, 2025.
 - [78] R. Ortalo, Y. Deswarte, and M. Kaaniche, "Experimenting with quantitative evaluation tools for monitoring operational security," *IEEE Transactions on Software Engineering*, vol. 25, no. 5, p. 633–650, 1999. [Online]. Available: <http://dx.doi.org/10.1109/32.815323>
 - [79] R. Mitchell and I.-R. Chen, "Modeling and Analysis of Attacks and Counter Defense Mechanisms for Cyber Physical Systems," *IEEE Transactions on Reliability*, vol. 65, no. 1, p. 350–358, March 2016. [Online]. Available: <http://dx.doi.org/10.1109/tr.2015.2406860>
 - [80] B. Genge, I. Kiss, and P. Haller, "A system dynamics approach for assessing the impact of cyber attacks on critical infrastructures," *International Journal of Critical Infrastructure Protection*, vol. 10, p. 3–17, 2015.
 - [81] G. Engelen, V. Rimmer, and W. Joosen, "Troubleshooting an Intrusion Detection Dataset: the CICIDS2017 Case Study," in *2021 IEEE Security and Privacy Workshops (SPW)*. IEEE, May 2021, p. 7–12. [Online]. Available: <http://dx.doi.org/10.1109/spw53761.2021.00009>
 - [82] M. Lanvin, P.-F. Gimenez, Y. Han, F. Majorczyk, L. Mé, and É. Totel, "Errors in the CICIDS2017 Dataset and the Significant Differences in Detection Performances It Makes," in *Risks and Security of Internet*

- and Systems. Springer Nature Switzerland, 2023, p. 18–33. [Online]. Available: http://dx.doi.org/10.1007/978-3-031-31108-6_2
- [83] S. Axelsson, “The base-rate fallacy and the difficulty of intrusion detection,” *ACM Transactions on Information and System Security*, vol. 3, no. 3, p. 186–205, August 2000. [Online]. Available: <http://dx.doi.org/10.1145/357830.357849>
- [84] R. Sommer and V. Paxson, “Outside the Closed World: On Using Machine Learning for Network Intrusion Detection,” in *2010 IEEE Symposium on Security and Privacy*. IEEE, 2010, p. 305–316. [Online]. Available: <http://dx.doi.org/10.1109/sp.2010.25>
- [85] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro, “TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time,” 2018, arXiv:1807.07838 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/1807.07838>
- [86] Z. Kan, S. McFadden, D. Arp, F. Pendlebury, R. Jordaney, J. Kinder, F. Pierazzi, and L. Cavallaro, “TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time (Extended Version),” 2024, arXiv:2402.01359 [cs.LG]. [Online]. Available: <https://arxiv.org/abs/2402.01359>
- [87] J. Gama, I. Žliobaitė, A. Bifet, M. Pechenizkiy, and A. Bouchachia, “A survey on concept drift adaptation,” *ACM Computing Surveys*, vol. 46, no. 4, p. 1–37, March 2014. [Online]. Available: <http://dx.doi.org/10.1145/2523813>
- [88] F. Barbero, F. Pendlebury, F. Pierazzi, and L. Cavallaro, “Transcending TRANSCEND: Revisiting Malware Classification in the Presence of Concept Drift,” in *2022 IEEE Symposium on Security and Privacy (SP)*. IEEE, May 2022, p. 805–823. [Online]. Available: <http://dx.doi.org/10.1109/sp46214.2022.9833659>
- [89] M. A. Haque, I. Hossain, M. M. Kamol, M. J. Alam, S. K. Amalapuram, S. Talukder, and M. S. Rahman, “LAMDA: A Longitudinal Android Malware Benchmark for Concept Drift Analysis,” arXiv:2505.18551, 2025. [Online]. Available: <https://arxiv.org/abs/2505.18551>
- [90] D. Arp, E. Quiring, F. Pendlebury, A. Warnecke, F. Pierazzi, C. Wressnegger, L. Cavallaro, and K. Rieck, “Dos and Don’ts of Machine Learning in Computer Security,” 2020, arXiv:2010.09470 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2010.09470>
- [91] C. Rossow, C. J. Dietrich, C. Grier, C. Kreibich, V. Paxson, N. Pohlmann, H. Bos, and M. v. Steen, “Prudent Practices for Designing Malware Experiments: Status Quo and Outlook,” in *2012 IEEE Symposium on Security and Privacy*. IEEE, May 2012, p. 65–79. [Online]. Available: <http://dx.doi.org/10.1109/sp.2012.14>
- [92] B. Biggio and F. Roli, “Wild patterns: Ten years after the rise of adversarial machine learning,” *Pattern Recognition*, vol. 84, p. 317–331, December 2018. [Online]. Available: <http://dx.doi.org/10.1016/j.patcog.2018.07.023>
- [93] A. Warnecke, D. Arp, C. Wressnegger, and K. Rieck, “Evaluating Explanation Methods for Deep Learning in Security,” in *2020 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, 2020, p. 158–174.
- [94] V. Z. Mohale and I. C. Obagbuwa, “Evaluating machine learning-based intrusion detection systems with explainable AI: enhancing transparency and interpretability,” *Frontiers in Computer Science*, vol. 7, May 2025. [Online]. Available: <http://dx.doi.org/10.3389/fcomp.2025.1520741>
- [95] A. Arcuri and L. Briand, “A practical guide for using statistical tests to assess randomized algorithms in software engineering,” in *Proceedings of the 33rd International Conference on Software Engineering*, ser. ICSE11. ACM, May 2011, p. 1–10. [Online]. Available: <http://dx.doi.org/10.1145/1985793.1985795>
- [96] G. Klees, A. Ruef, B. Cooper, S. Wei, and M. Hicks, “Evaluating Fuzz Testing,” in *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS ’18. ACM, October 2018, p. 2123–2138. [Online]. Available: <http://dx.doi.org/10.1145/3243734.3243804>
- [97] S. Gamage and J. Samarabandu, “Deep learning methods in network intrusion detection: A survey and an objective comparison,” *Journal of Network and Computer Applications*, vol. 169, p. 102767, November 2020. [Online]. Available: <http://dx.doi.org/10.1016/j.jnca.2020.102767>
- [98] C. Zhang, D. Jia, L. Wang, W. Wang, F. Liu, and A. Yang, “Comparative research on network intrusion detection methods based on machine learning,” *Computers & Security*, vol. 121, p. 102861, October 2022. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2022.102861>
- [99] J. Figueiredo, C. Serrão, and A. M. de Almeida, “Deep Learning Model Transposition for Network Intrusion Detection Systems,” *Electronics*, vol. 12, no. 2, p. 293, January 2023. [Online]. Available: <http://dx.doi.org/10.3390/electronics12020293>
- [100] N. Shone, T. N. Ngoc, V. D. Phai, and Q. Shi, “A Deep Learning Approach to Network Intrusion Detection,” *IEEE Transactions on Emerging Topics in Computational Intelligence*, vol. 2, no. 1, p. 41–50, February 2018. [Online]. Available: <http://dx.doi.org/10.1109/tetci.2017.2772792>
- [101] A. Javaid, Q. Niyaz, W. Sun, and M. Alam, “A Deep Learning Approach for Network Intrusion Detection System,” in *Proceedings of the 9th EAI International Conference on Bio-inspired Information and Communications Technologies (formerly BIONETICS)*, ser. BICT. ACM, 2016. [Online]. Available: <http://dx.doi.org/10.4108/eai.3-12-2015.2262516>
- [102] C. Yin, Y. Zhu, J. Fei, and X. He, “A Deep Learning Approach for Intrusion Detection Using Recurrent Neural Networks,” *IEEE Access*, vol. 5, p. 21954–21961, 2017. [Online]. Available: <http://dx.doi.org/10.1109/access.2017.2762418>
- [103] G. S. Collins, J. B. Reitsma, D. G. Altman, and K. G. Moons, “Transparent Reporting of a multivariable prediction model for Individual Prognosis Or Diagnosis (TRIPOD): The TRIPOD Statement,” *Annals of Internal Medicine*, vol. 162, no. 1, p. 55–63, January 2015. [Online]. Available: <http://dx.doi.org/10.7326/m14-0697>
- [104] J. Evertz, N. Risse, N. Neuer, A. Müller, P. Normann, G. Sapia, S. Gupta, D. Pape, S. Shaw, D. Srivastav, C. Wressnegger, E. Quiring, T. Eisenhofer, D. Arp, and L. Schönherr, “Chasing Shadows: Pitfalls in LLM Security Research,” 2025, arXiv:2512.09549 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2512.09549>
- [105] R. Karanjai, Y. Lu, H. H. Madhavarao, L. Xu, and W. Shi, “Context Contamination in LLM Analysis of Network Security Logs: Poison with Passive Prompt Injection and Mitigation Evaluation,” 2026, arXiv:2607.14493 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2607.14493>
- [106] A. A. Masoud, A. Anju, M. Arazzi, M. Cihangiroglu, V. K. Kambu, S. Nicolazzo, A. Nocera, V. P., and S. Sakthidharan, “Security in LLM-as-a-Judge: A Comprehensive SoK,” 2026, arXiv:2603.29403 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2603.29403>
- [107] J. D. Norman, M. U. Rivera, and D. A. Hughes, “Reliability without Validity: A Systematic, Large-Scale Evaluation of LLM-as-a-Judge Models Across Agreement, Consistency, and Bias,” 2026, arXiv:2606.19544 [cs.CL]. [Online]. Available: <https://arxiv.org/abs/2606.19544>
- [108] S. Abdelnabi, C. Hicks, K. Rieck, and A.-R. Sadeghi, “Measuring Security Without Fooling Ourselves: Why Benchmarking Agents Is Hard,” 2026, arXiv:2605.22568 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.22568>
- [109] B. Wu, G. Chen, K. Chen, X. Shang, J. Han, Y. He, W. Zhang, and N. Yu, “AutoPT: How Far Are We From the Fully Automated Web Penetration Testing?” *IEEE Transactions on Information Forensics and Security*, vol. 20, p. 9657–9672, 2025. [Online]. Available: <http://dx.doi.org/10.1109/tifs.2025.3601343>
- [110] J. W. Lin, E. K. Jones, D. J. Jasper, E. J. Shen Ho, A. Wu, A. T. Yang, N. Perry, A. Zou, M. Fredrikson, J. Z. Kolter, P. Liang, D. Boneh, and D. E. Ho, “Comparing AI Agents to Cybersecurity Professionals in Real-World Penetration Testing,” 2025, arXiv:2512.09882 [cs.AI]. [Online]. Available: <https://arxiv.org/abs/2512.09882>
- [111] A. Bertiger, B. Filar, A. Luthra, S. Meschiani, A. Mitchell, S. Scholten, and V. Sharath, “Evaluating LLM Generated Detection Rules in Cybersecurity,” 2025, arXiv:2509.16749 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2509.16749>
- [112] R. Holeman, J. Hastings, and V. M. Vaidyan, “Beyond Collection: Measuring the Detection Efficacy of Modern Security Logging Standards,” 2026, arXiv:2605.05531 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2605.05531>
- [113] X. Shen, Z. Li, G. Burleigh, L. Wang, and Y. Chen, “Decoding the MITRE Engenuity ATT&CK Enterprise Evaluation: An Analysis of EDR Performance in Real-World Environments,” 2024, arXiv:2401.15878 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2401.15878>
- [114] C. Larroche, “On fair and realistic performance evaluations for graph-based lateral movement detectors,” 2026, arXiv:2607.29390 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2607.29390>
- [115] F. Lupia, M. Lucchese, M. Merro, and N. Zannone, “ICS Honeypot Interactions: A Latitudinal Study,” in *2023 IEEE International Conference on Big Data (BigData)*. IEEE, December 2023, p. 3025–3034. [Online]. Available: <http://dx.doi.org/10.1109/bigdata59044.2023.10386497>

- [116] W. Tounsi and H. Rais, "A survey on technical threat intelligence in the age of sophisticated cyber attacks," *Computers & Security*, vol. 72, p. 212–233, January 2018. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2017.09.001>
- [117] C. Martins and I. Medeiros, "Generating Quality Threat Intelligence Leveraging OSINT and a Cyber Threat Unified Taxonomy," *ACM Transactions on Privacy and Security*, vol. 25, no. 3, p. 1–39, May 2022. [Online]. Available: <http://dx.doi.org/10.1145/3530977>
- [118] D. Schlette, M. Caselli, and G. Pernul, "A Comparative Study on Cyber Threat Intelligence: The Security Incident Response Perspective," *IEEE Communications Surveys & Tutorials*, vol. 23, no. 4, p. 2525–2556, 2021. [Online]. Available: <http://dx.doi.org/10.1109/comst.2021.3117338>
- [119] E. von Elm, D. G. Altman, M. Egger, S. J. Pocock, P. C. Gøtzsche, and J. P. Vandenbroucke, "The Strengthening the Reporting of Observational Studies in Epidemiology (STROBE) statement: guidelines for reporting observational studies," *The Lancet*, vol. 370, no. 9596, p. 1453–1457, October 2007. [Online]. Available: [http://dx.doi.org/10.1016/S0140-6736\(07\)61602-x](http://dx.doi.org/10.1016/S0140-6736(07)61602-x)
- [120] K. Campbell, L. A. Gordon, M. P. Loeb, and L. Zhou, "The economic cost of publicly announced information security breaches: empirical evidence from the stock market," *Journal of Computer Security*, vol. 11, no. 3, p. 431–448, 2003.
- [121] X. Sáez-de Cámara, J. L. Flores, C. Arellano, A. Urbiet, and U. Zurutuza, "Gotham Testbed: A Reproducible IoT Testbed for Security Experiments and Dataset Generation," *IEEE Transactions on Dependable and Secure Computing*, vol. 21, no. 1, p. 186–203, January 2024. [Online]. Available: <http://dx.doi.org/10.1109/dtsc.2023.3247166>
- [122] L. Bitzki, D. Kreutz, T. Heinrich, D. Fideles, L. Bertholdo, S. Quincozes, and A. Diniz, "NetSecBed: A Container-Native Testbed for Reproducible Cybersecurity Experimentation," 2026, arXiv:2604.04121 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.04121>
- [123] J. Dean, Y.-Z. Lin, J. P. M. Encinas, I. Almazayad, Q. Shi, Z. Yang, S. Satam, T. Lei, J. Zhang, S. Shao, S. Hariri, and P. Satam, "Federated Cybersecurity Testbed as a Service (FCTaaS): A framework to federate cybersecurity testbeds," 2026, arXiv:2607.10061 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2607.10061>
- [124] C. Skandylas and M. Asplund, "Automated Generation of Cybersecurity Exercise Scenarios," 2026, arXiv:2604.01079 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2604.01079>
- [125] A.-D. Tudosi, A. Graur, D. G. Balan, and A. D. Potorac, "Research on Security Weakness Using Penetration Testing in a Distributed Firewall," *Sensors*, vol. 23, no. 5, p. 2683, March 2023. [Online]. Available: <http://dx.doi.org/10.3390/s23052683>
- [126] R. Riccardi, Y. Yalamov, M. Campobasso, L. Allodi, H. Kool, A. Mon-eva, and E. R. Leukfeldt, "An Experimental Design to Investigate Attacker Actions on an Access-as-a-Service 'Criminal' Platform," in *2025 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, 2025, p. 109–114.
- [127] D. Yin, M. Mullarkey, G.-J. de Vreede, and M. Limayem, "Learning by Phishing via Post-Simulation Feedback: From Embedded to Non-Embedded Training," *MIS Quarterly*, vol. 50, no. 2, p. 767–784, 2026.
- [128] K. F. Schulz, D. G. Altman, D. Moher, and for the CONSORT Group, "CONSORT 2010 Statement: updated guidelines for reporting parallel group randomised trials," *BMJ*, vol. 340, no. mar23 1, p. c332–c332, March 2010. [Online]. Available: <http://dx.doi.org/10.1136/bmj.c332>
- [129] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer Berlin Heidelberg, 2012. [Online]. Available: <http://dx.doi.org/10.1007/978-3-642-29044-2>
- [130] G. Hatzivasilis, S. Ioannidis, M. Smyrlis, G. Spanoudakis, F. Frati, L. Goeke, T. Hildebrandt, G. Tsakirakis, F. Oikonomou, G. Leftheriotis, and H. Koshutanski, "Modern Aspects of Cyber-Security Training and Continuous Adaptation of Programmes to Trainees," *Applied Sciences*, vol. 10, no. 16, p. 5702, August 2020. [Online]. Available: <http://dx.doi.org/10.3390/app10165702>
- [131] B. D. Cone, C. E. Irvine, M. F. Thompson, and T. D. Nguyen, "A video game for cyber security training and awareness," *Computers & Security*, vol. 26, no. 1, p. 63–72, February 2007. [Online]. Available: <http://dx.doi.org/10.1016/j.cose.2006.10.005>
- [132] M. Glas, L. Kersten, T. Mulders, G. Pernul, and L. Allodi, "TIGER: An Instructional Re-Design of a Cyber Range Exercise in a Commercial Security Operations Center," in *Proceedings of the 2026 CHI Conference on Human Factors in Computing Systems*, ser. CHI '26. ACM, April 2026, p. 1–22. [Online]. Available: <http://dx.doi.org/10.1145/3772318.3791226>
- [133] J. S. Lee, W. J. Kettinger, and C. Zhang, "Nothing Like the Real Thing! A Randomized Field Experiment of Quasi-Mixed Reality Gamified Phishing Training," *ACM SIGMIS Database: the DATABASE for Advances in Information Systems*, vol. 56, no. 1, p. 61–78, January 2025. [Online]. Available: <http://dx.doi.org/10.1145/3715966.3715971>
- [134] S. Chaudhary, V. Gkioulos, and S. Katsikas, "A quest for research and knowledge gaps in cybersecurity awareness for small and medium-sized enterprises," *Computer Science Review*, vol. 50, p. 100592, November 2023. [Online]. Available: <http://dx.doi.org/10.1016/j.cosrev.2023.100592>
- [135] V. Distler, M. Fassl, H. Habib, K. Kromholz, G. Lenzini, C. Lallemand, L. F. Cranor, and V. Koenig, "A Systematic Literature Review of Empirical Methods and Risk Representation in Usable Privacy and Security Research," *ACM Transactions on Computer-Human Interaction*, vol. 28, no. 6, p. 1–50, December 2021. [Online]. Available: <http://dx.doi.org/10.1145/3469845>
- [136] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, "Incident response recommendations and considerations for cybersecurity risk management: a CSF 2.0 community profile," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-61r3, April 2025. [Online]. Available: <http://dx.doi.org/10.6028/nist.sp.800-61r3>
- [137] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," National Institute of Standards and Technology, Tech. Rep., February 2024, nIST CSWP 29. [Online]. Available: <http://dx.doi.org/10.6028/nist.cswp.29>
- [138] R. Ruefle, A. Dorofee, D. Mundie, A. D. Householder, M. Murray, and S. J. Perl, "Computer Security Incident Response Team Development and Evolution," *IEEE Security & Privacy*, vol. 12, no. 5, p. 16–26, 2014.
- [139] A. Valjarevic and H. S. Venter, "Harmonised digital forensic investigation process model," in *2012 Information Security for South Africa*. IEEE, August 2012, p. 1–10. [Online]. Available: <http://dx.doi.org/10.1109/issa.2012.6320441>
- [140] —, "A Comprehensive and Harmonized Digital Forensic Investigation Process Model," *Journal of Forensic Sciences*, vol. 60, no. 6, p. 1467–1483, August 2015. [Online]. Available: <http://dx.doi.org/10.1111/1556-4029.12823>
- [141] C. Hargreaves, A. Nelson, and E. Casey, "An abstract model for digital forensic analysis tools - A foundation for systematic error mitigation analysis," *Forensic Science International: Digital Investigation*, vol. 48, p. 301679, March 2024. [Online]. Available: <http://dx.doi.org/10.1016/j.fsidi.2023.301679>
- [142] A. Pigola and F. d. S. Meirelles, "Zero trust in cybersecurity: managing critical challenges for effective implementation," *Journal of Systems and Information Technology*, vol. 27, no. 4, p. 517–564, April 2025. [Online]. Available: <http://dx.doi.org/10.1108/jisit-08-2024-0326>
- [143] D. Olszewski, A. Lu, C. Stillman, K. Warren, C. Kitroser, A. Pascual, D. Ukirde, K. Butler, and P. Traynor, "Get in Researchers; We're Measuring Reproducibility": A Reproducibility Study of Machine Learning Papers in Tier 1 Security Conferences," in *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS '23. ACM, November 2023, p. 3433–3459. [Online]. Available: <http://dx.doi.org/10.1145/3576915.3623130>
- [144] D. Olszewski, A. Lu, A. Crowder, N. Bennett, S. Layton, S. H. Varma Bhupathiraju, T. Tucker, S. Kalgutkar, H. Ver Helst, C. Stillman, K. R. B. Butler, S. Rampazzi, and P. Traynor, "Reproducibility in Applied Security Conferences: An 11-Year Review on Artifacts and Evaluation Committees," in *Proceedings of the 3rd ACM Conference on Reproducibility and Replicability*. ACM, 2025, p. 96–107.
- [145] A. Crowder, A. Lu, K. Childs, C. Stillman, P. Traynor, and K. R. Butler, "Data to Infinity and Beyond: Examining Data Sharing and Reuse Practices in the Computer Security Community," in *2025 IEEE Symposium on Security and Privacy (SP)*. IEEE, May 2025, p. 2678–2696. [Online]. Available: <http://dx.doi.org/10.1109/sp61157.2025.00180>
- [146] D. Mendez, D. Graziotin, S. Wagner, and H. Seibold, "Open Science in Software Engineering," in *Contemporary Empirical Methods in Software Engineering*. Springer International Publishing, 2020, p. 477–501. [Online]. Available: http://dx.doi.org/10.1007/978-3-030-32489-6_17
- [147] N. Rani and C. Rossow, "On the Security of Research Artifacts," arXiv:2605.06508, 2026. [Online]. Available: <https://arxiv.org/abs/2605.06508>
- [148] J. Ayala, Y.-J. Tung, and J. Garcia, "Investigating Vulnerability Disclosures in Open-Source Software Using Bug Bounty Reports and Security Advisories," arXiv:2501.17748, 2025. [Online]. Available: <https://arxiv.org/abs/2501.17748>

- [149] D. Dittrich, E. E. Kenneally, and M. Bailey, "Applying Ethical Principles to Information and Communication Technology Research: A Companion to the Menlo Report," SSRN preprint, 2013. [Online]. Available: <http://dx.doi.org/10.2139/ssrn.2342036>
- [150] T. Kohno, Y. Acar, and W. Loh, "Ethical Frameworks and Computer Security Trolley Problems: Foundations for Conversations," arXiv:2302.14326, 2023. [Online]. Available: <https://arxiv.org/abs/2302.14326>
- [151] L. Biggi, J. Rioja, P. Castaneda, J. Mansilla-Lopez, and A. D. Garcia-Nunez, "Development and Validation of a Cybersecurity Model for Ransomware Mitigation Based on NIST CSF 2.0: The Case Study of a Peruvian Micro-Small Enterprise," *Engineering, Technology & Applied Science Research*, vol. 15, no. 6, p. 30015–30025, December 2025. [Online]. Available: <http://dx.doi.org/10.48084/etasr.12948>